Support de cours : Sécurité Informatique

Master en Ingénierie Informatique, S3 (2014-2023)

Prof. Noura Ouerdi

Université Mohammed Premier

Faculté des Sciences

Département d'Informatique

Oujda - MAROC

Table des matières

Chapitre 1 Introduction à la sécurité Informatique 6
1.1 Introduction 7
1.1.1 Statistiques récentes 7
1.1.2 Conseils clés pour se prémunir des malwares 8
1.1.3 Cybersécurité et quelle différence avec la sécurité informatique? 8
1.2 Critères et objectifs fondamentaux de la sécurité informatique 9
1.2.1 Critère de disponibilité 9
1.2.2 L'intégrité 10
1.2.3 La confidentialité 10
1.3 L'identification et l'authentification 10
1.3.1 La non-répudiation 11
1.4 Les domaines d'application de la sécurité 11
1.4.1 La sécurité physique 11
1.4.2 Sécurité de l'exploitation 12
1.4.3 La sécurité logique 12
1.4.4 La sécurité applicative 12
1.4.5 La sécurité des télécommunications 13
1.5 Sécurité et criminalité informatique 13
1.5.1 Criminalité informatique 13
1.5.2 Internet : Point de vue technique 13
1.5.3 Notion de port et protocole 14
1.5.4 Autres définitions 15
1.6 Les attaques 15
1.6.1 Attaques par rebond 18
1.7 Les pirates 18
1.8 Principales menaces liées à Internet 19
1.8.1 Sniffing : écoute du réseau 19
1.8.2 Hijacking : usurpation d'identité 20
1.8.3 Spamming – Mail bombing 20
1.8.4 Chevaux de troie 20

1.8.5 Vers de courrier 20
1.8.6 Le social engineering 20
Chapitre 2 Capture réseau avec Wireshark 22
2.1 Introduction 23
2.2 Lancement de Wireshark 23
2.3 Analyse des informations de trafic Web 24
2.4 Analyse d'un paquet : Encapsulation d'un paquet 25
2.4.1 Rappel 25
2.4.2 Détail du paquet 27
2.4.3 Visualisation hexadécimale de la trame 28
2.4.4 Principe et mise en place d'un filtre 28
Chapitre 3 Attaques cryptographiques 30
3.1 Introduction 31
3.2 Attaques cryptographiques 31
3.2.1 Les mots de passe 31
3.2.2 Attaque man in the middle 33
3.2.3 Attaque par rejeu 33
3.2.4 Introduction aux attaques par déni de service 33
Chapitre 4 Cryptographie 43
4.1 Principes fondamentaux (Rappel) 44
4.1.1 Vocabulaire 44
4.1.2 Taille de la clé 44
4.2 Cryptographie symétrique et asymétrique 45
4.2.1 Systèmes de chiffrement symétrique 45
4.2.2 Principaux algorithmes 47
4.2.3 Cryptanalyse 47
4.2.4 Limites du chiffrement symétrique 48
4.3 Système de chiffrement asymétrique 48
4.4 Clés secrètes 50
Chapitre 5 Infrastructure de gestion de clés (PKI) 52
5.1 Définition 53
5.2 Composants clés de la PKI 53
5.3 Fonctionnement de la PKI 53
5.4 Raisons de révocation d'un certificat 54
5.4.1 Utilisations de la PKI 54
5.4.2 Infrastructure de gestion de clés 54

5.4.3 Certificat numérique 54
5.4.4 Principaux paramètres d' un certificat numérique selon la norme X.509 55
5.4.5 Limites 56
5.4.6 Exemple de transaction sécurisée par l'intermédiaire d'une PKI 56
5.4.7 Cas particulier d'autorité de certification privée 57
5.5 Empreinte d'un message 57
5.6 Signature numérique 60
5.7 Signature et hachage 60
5.8 Certificat/ signature numérique 61
Chapitre 6 IDS : Systèmes de détection d'intrusion 62
6.1 Introduction 63
6.2 Les différents types d'IDS 63
6.2.1 Les systèmes de détection d'intrusions "réseaux" (NIDS) 63
6.2.2 Les systèmes de détection d'intrusions de type hôte (HIDS) 64
6.2.3 Les systèmes de détection d'intrusions "hybrides" 64
6.2.4 Les systèmes de prévention d'intrusions (IPS) 64
6.2.5 Les IPS "noyau" (KIDS/KIPS) 65
6.3 Les méthodes de détections 66
6.3.1 L'approche par scénario 66
6.3.2 L'approche comportementale 67
6.3.3 Inconvénients de l'approche comportementale 68
6.3.4 Différentes méthodes dans l'approche comportementale 68
6.4 Les méthodes répandues 68
6.5 Principes généraux et déploiement 69
6.6 Fonctionnement d'un IDS 69
6.6.1 Les étapes de fonctionnement 69
6.6.2 Les outils 70
Chapitre 7 Iptables : Parfeu Linux 71
7.1 Définition 73
7.2 Iptables: Configuration des tables et chaînes du pare-feu intégré 73
7.2.1 Table nat 73
7.2.2 Table mangle 74
7.2.3 Syntaxe d'iptables 74
7.3 Iptables: Configurer la table NAT du pare-feu 79
7.3.1 Le DNAT ou NAT Destination 80
7.3.2 Le SNAT ou NAT Source 80

7.3.3 L'IP Masquerade 80
Chapitre 8 Proxy 82
8.1 Introduction 83
8.2 Principe de fonctionnement d'un proxy 83
8.3 Les fonctionnalités d'un serveur proxy 83
8.3.1 La fonction de cache 83
8.3.2 Le filtrage 84
8.3.3 L'authentification 84
8.4 Les reverse-proxy 85
8.4.1 Mise en place d'un serveur proxy 85

Chapitre 1 Introduction à la sécurité Informatique

1.1 Introduction

La **sécurité des systèmes d'information** (**SSI**) ou plus simplement **sécurité informatique**, est l'ensemble des moyens techniques, organisationnels, juridiques et humains visant à empêcher l'utilisation non-autorisée, le mauvais usage, la modification ou le détournement du système d'information.

La sécurité informatique est un domaine vaste qui peut exister dans plusieurs domaines:

→ Les systèmes d'informations

→ Les réseaux informatiques

→ Les accès physiques à des salles machines

Nous nous concentrerons sur les aspects relatifs aux systèmes informatiques et réseaux

1.1.1 Statistiques récentes

- 93.6% des logiciels malveillants sont polymorphes - Changement constant de son code pour échapper à la détection.
- 62% des appareils infectés par des logiciels malveillants étaient des appareils grand public (utilisateurs à domicile), tandis que 38% étaient des systèmes d'entreprise.
- Windows 10 est un système d'exploitation (OS) plus sûr que les itérations précédentes. Les systèmes exécutant Windows 7 sont près de 3 fois plus susceptibles d'être infectés par des logiciels malveillants que les appareils Windows 10.
- Les attaques DDoS ont augmenté de près de 50% en 2019
- les cybercriminels ont profité de la pandémie de COVID-19 et ont lancé près de 5 millions d'attaques au cours du seul premier semestre 2020. Il ont ciblé principalement le commerce électronique, les soins de santé et les services éducatifs.
- 20% des Américains ont fait face à des attaques de ransomware
- Le rapport annuel 2018 sur la cybersécurité de Cisco a documenté les types d'extensions de fichiers malveillants couramment utilisés dans les documents de courrier électronique. Il a été constaté que les formats Microsoft Office tels que Word, PowerPoint et Excel figuraient en tête de liste.
- 65% des transactions frauduleuses commencent sur des appareils mobiles

- Facebook a perdu plus de 309 millions d'enregistrements de données en 2019. En mars 2020, un deuxième serveur a de nouveau été attaqué par le même groupe criminel. Cette fois, 42 millions d'enregistrements supplémentaires ont été divulgués,
- L'erreur humaine est à l'origine de plus de 95% des violations de cybersécurité

1.1.2 Conseils clés pour se prémunir des malwares

Pour se protéger face à la propagation continuelle des menaces provenant de logiciels malwares, la solution VPN encourage les utilisateurs à :

- **Effectuer ses mises à jour logicielles régulièrement :** selon les outils et les applications que vous utilisez au quotidien, il est important d'effectuer les mises à jour quand elles vous sont proposées. Les développeurs de logiciels appliquent régulièrement des correctifs au sein de ces mises à jour, afin de corriger des failles de sécurité qui pourraient ou qui ont été exploitées.
- **Rester vigilant lorsque vous réalisez des téléchargements :** il est commun de voir les logiciels malveillants être intégrés à des fichiers ou applications téléchargés. Veillez ainsi à réaliser vos téléchargements depuis des sources et des stores officiels.
- **Éviter les liens et pièces jointes suspects :** (phishing) est une technique très répandue en matière de malwares. C'est pourquoi il est important de rester en alerte sur les emails que vous recevez. Il est ainsi fortement recommandé de ne pas cliquer sur des liens ou ouvrir une pièce jointe dès lors qu'un email vous semble suspect.
- **Utiliser un logiciel antivirus :** s'il faut le rappeler, l'utilisation d'un antivirus est indispensable pour votre ordinateur et votre mobile. Cette protection ne doit pas être prise à la légère au risque de se voir dérober des données personnelles ou d'être victime de ransomwares, autre type de cyberattaque de plus en plus répandue.

1.1.3 Cybersécurité et quelle différence avec la sécurité informatique?

La sécurité informatique fait référence à l'ensemble des mesures, des pratiques et des technologies visant à protéger les systèmes informatiques, les logiciels, les données et les infrastructures contre les menaces, qu'elles soient intentionnelles (comme les virus) ou non

intentionnelles (comme des pannes matérielles ou des erreurs humaines). Elle englobe tout ce qui est lié à la protection des systèmes d'information dans un contexte informatique, qu'ils soient connectés à internet ou non. Cela inclut des aspects tels que la protection des fichiers, la gestion des accès, la sauvegarde des données, et la sécurité physique des infrastructures informatiques (salles serveurs, dispositifs de stockage, etc.).

La cybersécurité est une sous-discipline de la sécurité informatique, mais elle se concentre spécifiquement sur la protection des systèmes, des réseaux, et des données contre les cyberattaques menées via Internet ou d'autres réseaux numériques.

Elle couvre des domaines comme la sécurité des réseaux, la sécurité des applications web, la protection contre les attaques par phishing, les ransomwares, ou encore les intrusions dans les réseaux.

En résumé, la **sécurité informatique** concerne la protection des systèmes et données dans un cadre informatique large, tandis que la **cybersécurité** est spécifiquement axée sur la protection contre les menaces venant du cyberespace.

1.2 Critères et objectifs fondamentaux de la sécurité informatique

Les solutions de sécurité doivent contribuer à satisfaire au moins les critères suivants:

- La disponibilité
- L'intégrité
- La confidentialité

À ces critères, nous pouvons ajouter :

- L'authentification
- La non-répudiation

1.2.1 Critère de disponibilité

La disponibilité est indissociable de l'accessibilité. Une ressource doit être accessible, avec un temps de réponse acceptable. La disponibilité des services, systèmes et données. Un service doit aussi être assuré avec le minimum d'interruption en respect avec l'engagement établi. De

plus des pertes de données sont possibles si l'enregistrement et le stockage ne sont pas gérés correctement, d'où l'importance d'une haute disponibilité d'un système et de la mise en place d'une politique de sauvegarde.

1.2.2 L'intégrité

L'intégrité permet de certifier que les données, les traitements ou les services n'ont pas été modifiés, altérés ou détruits tant de façon intentionnelle qu'accidentelle. L'altération est principalement occasionnée par le média de transmission mais peut provenir du système d'informations. Il faut également veiller à garantir la protection des données d'une écoute active sur le réseau. Ces écoutes peuvent modifier les données interceptées.

1.2.3 La confidentialité

« La confidentialité est le maintien du secret des informations » (Le Petit Robert).

Dans le cadre d'un système d'information, cela peut être vu comme une protection des données contre une divulgation non autorisée.

2 actions complémentaires permettant d'assurer la confidentialité des données :

- Limiter leur accès par un mécanisme de contrôle d'accès
- Transformer les données par des procédures de chiffrement

1.3 L'identification et l'authentification

L'identification de l'auteur d'un document peut être facile par contre être en mesure d'assurer l'authenticité du document est chose plus délicate. Ces mesures doivent être mises en place afin d'assurer :

- La confidentialité et l'intégrité des données d'une personne.
- La non répudiation, c'est à dire qu'une personne identifiée et authentifiée ne peut nier une action.

L'identification peut être vu comme un simple login de connexion sur un système.

L'authentification peut être un mot de passe connu seulement par l'utilisateur.

1.3.1 La non-répudiation

La non-répudiation est le fait de ne pouvoir nier ou rejeter qu'un événement (action, transaction) a eu lieu.

A cette notion sont associées :

- L'imputabilité se définit par l'affectation certaine d'une entité à une action. De ce fait; une action a eu lieu et automatiquement un enregistrement, preuve de l'action, est effectué.
- La traçabilité : mémorisation de l'origine du message(adresse)
- L'auditabilité : capacité d'un système à garantir la présence d'informations nécessaires à une analyse ultérieure d'un événement dans le but de déterminer s'il y a eu violation de la sécurité.

L'existence de fichiers journaux permet de garantir l'imputabilité et l'auditabilité.

1.4 Les domaines d'application de la sécurité

Tous les domaines de l'informatique sont concernés par la sécurité d'un système d'information

En fonction de son domaine d'application, la sécurité informatique se décline en:

- Sécurité physique
- Sécurité de l'exploitation
- Sécurité logique
- Sécurité applicative
- Sécurité des télécommunications

1.4.1 La sécurité physique

Concerne tous les aspects liés de l'environnement dans lequel les systèmes se trouvent.

La sécurité physique passe donc par :

- Des normes de sécurité
- Protection de l'environnement (incendie, température, humidité, ...) et ressources énergétique(alimentation)
- Protection des accès (protection physique des équipements, …)
- Fiabilité des matériels (câbles, composants, …)
- Plan de maintenance préventive (test, ...) et corrective (pièce de rechange, ...)

1.4.2 Sécurité de l'exploitation

Rapport à tous ce qui touche au bon fonctionnement des systèmes. Cela comprend la mise en place d'outils et de procédures relatifs aux méthodologies d'exploitation, de maintenance, de test, de diagnostic et de mise à jour. La sécurité de l'exploitation dépend fortement de son degré d'industrialisation qui est qualifié par le niveau de supervision des applications et l'automatisation des tâches.

Quelques points clés de cette sécurité

- Plan de sauvegarde, de continuité, de tests
- Inventaire régulier et si possible dynamique
- Gestion du parc informatique, des configurations et des mises à jour
- Contrôle et suivie de l'exploitation.

1.4.3 La sécurité logique

La sécurité logique fait référence à la réalisation de mécanismes de sécurité par logiciel.

Elle repose sur la mise en œuvre d'un système de contrôle d'accès logique s'appuyant sur un service d'authentification, d'identification et d'autorisation. Elle repose également sur

- Les dispositifs mis en place pour garantir la confidentialité dont la cryptographie
- Une gestion efficace des mots de passe et des procédures d'authentification
- Des mesures antivirus et de sauvegarde des informations sensibles

Pour déterminer le niveau de protection nécessaire aux informations manipulées, une classification des données est à réaliser pour qualifier leur degré de sensibilité (normale, confidentielle, top secrète, ...)

1.4.4 La sécurité applicative

Faire un développement pertinent et l'intégrer harmonieusement dans les applications existantes.

Cette sécurité repose essentiellement sur :

- Une méthodologie de développement
- La robustesse des applications
- Des contrôles programmés
- Des jeux de tests
- Un plan de migration des applications critiques
- La validation et l'audit des programmes

- Un plan d'assurance sécurité

1.4.5 La sécurité des télécommunications

Offrir à l'utilisateur final une connectivité fiable et de qualité de « bout en bout » (end to end security). Il faut donc mettre un canal de communication fiable entre les correspondants, quels que soient le nombre et la nature des éléments intermédiaires. Cela implique la réalisation d'une infrastructure réseau sécurisée au niveau des accès, des protocoles de communication, des systèmes d'exploitation et des équipements.

1.5 Sécurité et criminalité informatique

1.5.1 Criminalité informatique

Un crime informatique (computer related crime) est un délit pour lequel un système informatique est l'objet du délit et/ou le moyen de le réaliser.

Le cybercrime (cyber crime) est une forme de crime informatique qui fait appel aux technologies internet pour sa réalisation.

1.5.2 Internet : Point de vue technique

Internet : interconnexion de réseaux à l'échelle planétaire, constitué de millions de serveurs reliés entre eux physiquement, pour constituer une toile d'araignée.

Pour permettre aux internautes d'accéder aux sites par leurs noms, on a inventé :

Le D.N.S. : Domain Name Service

✓ Il s'agit d'un système de correspondance qui traduit un nom de machine en adresse IP :

Nom de machine ⇦⇨ Adresse IP

✓ Le D.N.S. est à comparer à un annuaire téléphonique :

Nom de l'abonné ⇦⇨ Numéro de téléphone

✓ Le D.N.S. répartit les machines au niveau géographique en fonction des pays :

_____ . fr	France
_____ . de	Allemagne
_____ . it	Italie
_____ . Tw	Taiwan

✓ Et en fonction de certains types particuliers :

_____ . com commercial

_____ . org organisation

_____ . net réseau

_____ . int international

_____ . gov government

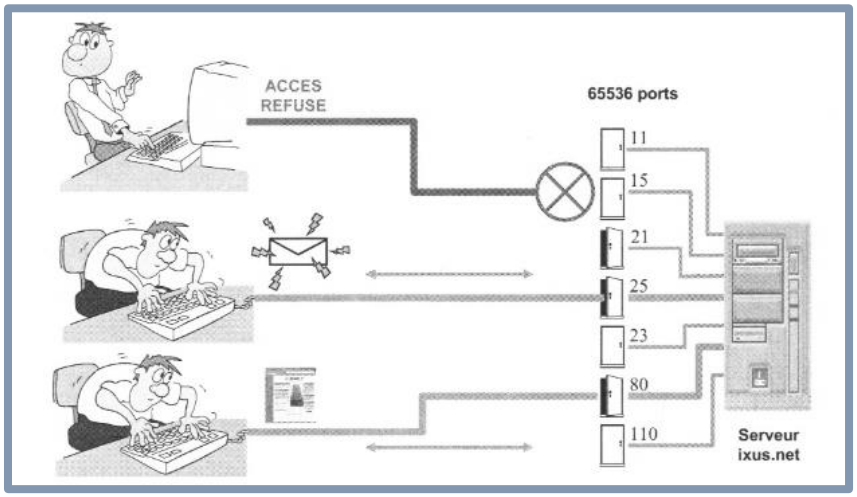
_____ . edu education

_____ . mil military

1.5.3 Notion de port et protocole

Une fois que le serveur est contacté, il faut trouver un moyen pour s'y connecter. Pour ce faire, un serveur est équipé de ports. Les ports peuvent être assimilés aux portes d'entrée de la machine, au nombre de 65536 et numérotées.

Chaque serveur admet donc simultanément un nombre élevé de clients.



La liaison établie, le client doit trouver un moyen de converser avec le serveur. Pour cela ont été inventés les protocoles. Les protocoles correspondent à des normes et permettent aux ordinateurs de se comprendre.

Il existe de nombreux protocoles différents pour converser avec les différents ports d'un serveur.

Les principaux protocoles :

. IP : Internet protocol (données qui circulent)

. TCP : contrôle du transport des données

~~~~~~~~~~~~~~~

. HTTP : pour transmettre le contenu du Web (www)

. SMTP : Pour envoyer des courriers électroniques

. POP : Pour récupérer ses courriers électroniques

. FTP : Pour le téléchargement de fichiers
~~~~~~~~~~~~~~~

. NNTP : Pour la lecture des forums (newsgroups)

. IRC : Pour la discussion écrite en temps réel

. TELNET : Connexion à distance sur un ordinateur

1.5.4 Autres définitions

Définition de base : La sécurité informatique c'est l'ensemble des moyens mis en œuvre pour minimiser la vulnérabilité d'un système contre des menaces accidentelles ou intentionnelles.

- Sécurité = “Safety”

Protection de systèmes informatiques contre les accidents dus à l'environnement, les défauts du système.

- Sécurité = “Security ”

Protection des systèmes informatiques contre des actions malveillantes intentionnelles.

Note : Une vulnérabilité (ou faille) est une faiblesse dans un système informatique.

En général, Le **risque** en termes de sécurité est caractérisé par l'équation suivante :

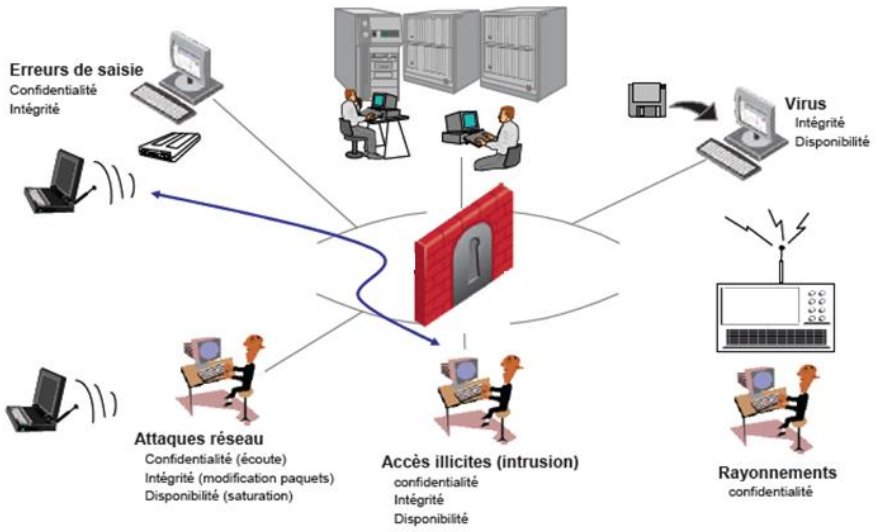
$$Risque = \frac{Menace \times Vulnérabilité}{Contre - mesure}$$

- La **menace** représente le type d'action susceptible de nuire dans l'absolu.
- La **vulnérabilité** (appelée parfois faille) représente le niveau d'exposition face à la menace dans un contexte particulier.
- La **contre-mesure** est l'ensemble des actions mises en œuvre en prévention de la menace.
- Note : Les contre-mesures à mettre en œuvre ne sont pas uniquement des solutions techniques mais également des mesures de formation et de sensibilisation à l'intention des utilisateurs, ainsi qu'un ensemble de règles clairement définies.

1.6 Les attaques

Tout ordinateur connecté à un réseau informatique est potentiellement vulnérable à une **attaque**.

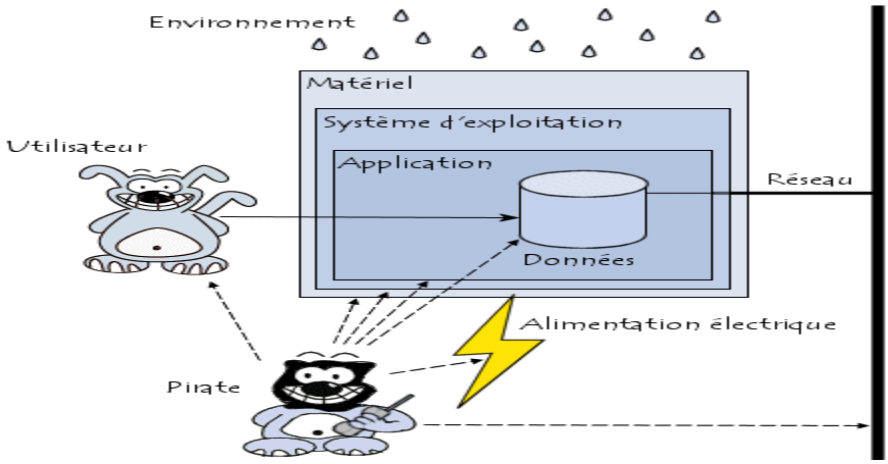
Une attaque est l'exploitation d'une faille d'un système informatique (système d'exploitation, logiciel ou bien même de l'utilisateur) à des fins non connues par l'exploitant du système.



Les motivations des attaques peuvent être de différentes sortes :

- obtenir un accès au système,
- voler des informations, tels que des secrets industriels ou des propriétés intellectuelles,
- avoir des informations personnelles sur un utilisateur,
- récupérer des données bancaires,
- s'informer sur l'organisation (entreprise de l'utilisateur, etc.),
- troubler le bon fonctionnement d'un service,
- utiliser le système de l'utilisateur comme “rebond” pour une attaque,
- utiliser les ressources du système de l'utilisateur, notamment lorsque le réseau sur lequel il est situé possède une bande passante élevée.

Les systèmes informatiques mettent en œuvre différentes composantes, allant de l'électricité pour alimenter les machines au logiciel exécuté via le système d'exploitation et utilisant le réseau. Les attaques peuvent intervenir à chaque maillon de cette chaîne, pour peu qu'il existe une vulnérabilité exploitable.



Il est possible de catégoriser les risques de la manière suivante :

- **Accès physique** : il s'agit d'un cas où l'attaquant a accès aux locaux, éventuellement même aux machines :
    - Coupure de l'électricité
    - Extinction manuelle de l'ordinateur
    - Vandalisme : Destruction ou endommage
    - Ouverture du boîtier de l'ordinateur et vol de disque dur
    - Ecoute du trafic sur le réseau
- **Interception de communications** :
    - Vol de session (session hacking)
    - Usurpation d'identité
    - Détournement ou altération de messages
- **Dénis de service** : il s'agit d'attaques visant à perturber le bon fonctionnement d'un service. On distingue habituellement les types de déni de service suivant :
    - Exploitation de faiblesses des protocoles TCP/IP
    - Exploitation de vulnérabilité des logiciels serveurs
- **Intrusions** :
    - Balayage de ports (port scanning)
    - Elévation de privilèges : ce type d'attaque consiste à exploiter une vulnérabilité d'une application en envoyant une requête spécifique, non prévue par son concepteur, ayant pour effet un comportement anormal conduisant parfois à un accès au système avec les droits de l'application. Les attaques par débordement de tampon (buffer overflow) utilisent ce principe.
    - Maliciels (virus, vers et chevaux de Troie)
- **Ingénierie sociale** : Dans la majeure partie des cas le maillon faible est l'utilisateur lui-même! En effet c'est souvent lui qui, par méconnaissance ou par duperie, va ouvrir une faille dans le système, en donnant des informations (mot de passe par exemple) au pirate informatique ou en exécutant une pièce jointe.
- **Trappes** : Il s'agit d'une porte dérobée (backdoor) dissimulée dans un logiciel, permettant un accès ultérieur à son concepteur.
- Les erreurs de programmation contenues dans les programmes sont habituellement corrigées assez rapidement par leur concepteur dès lors que la vulnérabilité a été **publiée**.
- Il appartient aux administrateurs de se tenir informés **des mises à jour** des programmes qu'ils utilisent afin de limiter les risques d'attaques.

- La sécurisation d'un système informatique est généralement dite “**asymétrique**”, dans la mesure où le pirate n'a qu'à trouver une seule vulnérabilité pour compromette le système, tandis que l'administrateur doit corriger toutes les failles.

1.6.1 Attaques par rebond

- Lors d'une attaque, le pirate garde toujours à l'esprit le risque de se faire repérer.
- C'est la raison pour laquelle les pirates privilégient habituellement les **attaques par rebond** (par opposition aux attaques directes), consistant à attaquer une machine par l'intermédiaire d'une autre machine.
- L’objectif est de masquer les traces permettant de remonter à lui (telle que son adresse IP) et dans le but d'utiliser les ressources de la machine servant de rebond.
- Avec le développement des réseaux sans fils, ce type de scénario risque de devenir de plus en plus courant car lorsque le réseau sans fil est mal sécurisé, un pirate situé à proximité peut l'utiliser pour lancer des attaques.

1.7 Les pirates

Le terme “**hacker**” est souvent utilisé pour désigner un **pirate** informatique.

A l'origine ce nom désignait les programmeurs expérimentés.

Aujourd'hui ce mot est souvent utilisé à tort pour désigner les personnes s'introduisant dans les systèmes informatiques.

Les différents types de pirates

En réalité il existe de nombreux types d’ attaquants catégorisés selon leur expérience et selon leurs motivations :

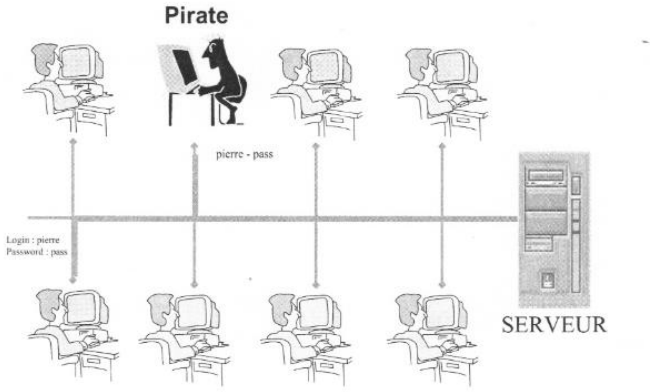
- Les “**white hat hackers**”, hackers au sens noble du terme, dont le but est d'aider à l'amélioration des systèmes et technologies informatiques, sont généralement à l'origine des principaux protocoles et outils informatiques que nous utilisons aujourd'hui;
- Les “**hacktivistes**” (cybermilitant ou cyberrésistant), sont des hackers dont la motivation est principalement idéologique, utilisant des compétences du piratage informatique dans le but de favoriser des changements politiques ou sociétaux.
- Les “**black hat hackers**”, plus couramment appelés pirates, c'est-à-dire des personnes s'introduisant dans les systèmes informatiques dans un but nuisible ;
    - Les “script kiddies” (traduisés gamins du script) sont de jeunes utilisateurs du réseau utilisant des programmes trouvés sur Internet, généralement de façon maladroite, pour vandaliser des systèmes informatiques afin de s'amuser.
    - Les “phreakers” sont des pirates s'intéressant au réseau téléphonique commuté (RTC) afin de téléphoner gratuitement grâce à des circuits électroniques connectés à la ligne téléphonique dans le but d'en falsifier le fonctionnement.

- Les “carders” s'attaquent principalement aux systèmes de cartes à puces (en particulier les cartes bancaires) pour en comprendre le fonctionnement et en exploiter les failles.
- Les “crackers” sont des personnes dont le but est de créer des outils logiciels permettant d'attaquer des systèmes informatiques ou de casser les protections contre la copie des logiciels payants. Un “crack” est ainsi un programme créé exécutable chargé de modifier (patcher) le logiciel original afin d'en supprimer les protections.

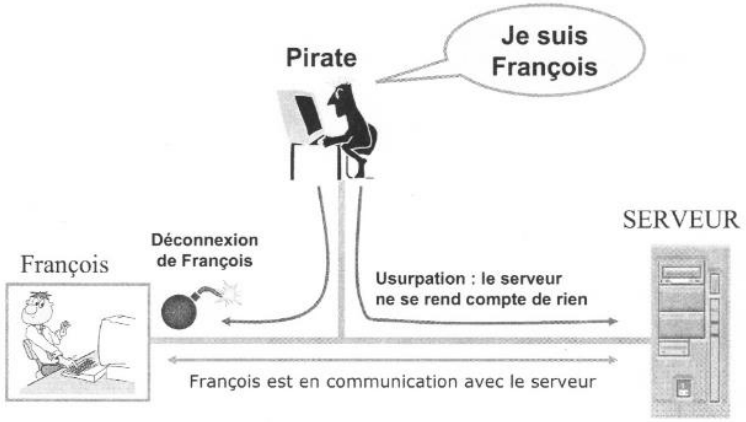
1.8 Principales menaces liées à Internet

⇨ Sniffing : écoute du réseau
⇨ Hijacking : usurpation d’identité
⇨ Flooding : saturation volontaire d’un ordinateur
⇨ Craking : intrusion dans un système de traitement (hacking) automatisé de donnée (STAD)
⇨ Mail bombing / spamming : saturation volontaire de la boîte à lettre électronique d’un internaute par l’envoi en grand nombre de mails non sollicités
⇨ Autres : virus, chevaux de troie, spoofing…

1.8.1 Sniffing : écoute du réseau



1.8.2 Hijacking : usurpation d'identité



1.8.3 Spamming – Mail bombing

Les pirates exploitent quelquefois un serveur d'entreprise mal configuré ou piraté pour envoyer en grand nombre des courriers électroniques : Spamming ou encore mail bombing

Ces actions peuvent avoir plusieurs objectifs :

- saturer la boîte à lettre d'un internaute

- saturer le serveur de l'entreprise par lequel est effectué l'envoi des mails

- envoyer des courriers publicitaires non sollicités par les internautes…

1.8.4 Chevaux de troie

Les pirates « débutants » utilisent des logiciels développés par des hackers (spécialistes des systèmes d'exploitation) pour s'introduire dans les ordinateurs : les chevaux de troie (trojans)

1.8.5 Vers de courrier

Il existe également des scripts (programmes) exploitant les failles des systèmes Windows et se propageant par le courrier électronique : les vers.

✓ Lorsqu'ils s'exécutent sur un ordinateur, ces scripts parcourent le carnet d'adresse de l'internaute et s'auto-expédient à tous les correspondants enregistrés.

✓ Ces vers sont capables de se diffuser d'eux-mêmes très largement sur Internet en seulement quelques heures, paralysant ainsi de nombreux serveurs.

Exemple : The LoveLetter

1.8.6 Le social engineering

Le social engineering est le fait de tenter des renseignements de manière psychologique

✓ En se faisant passer pour une personne dans laquelle l'utilisateur a confiance ou qui a autorité sur lui

✓ L’utilisateur peut-être trompé et divulguer des informations qui mettent en péril la sécurité du système.

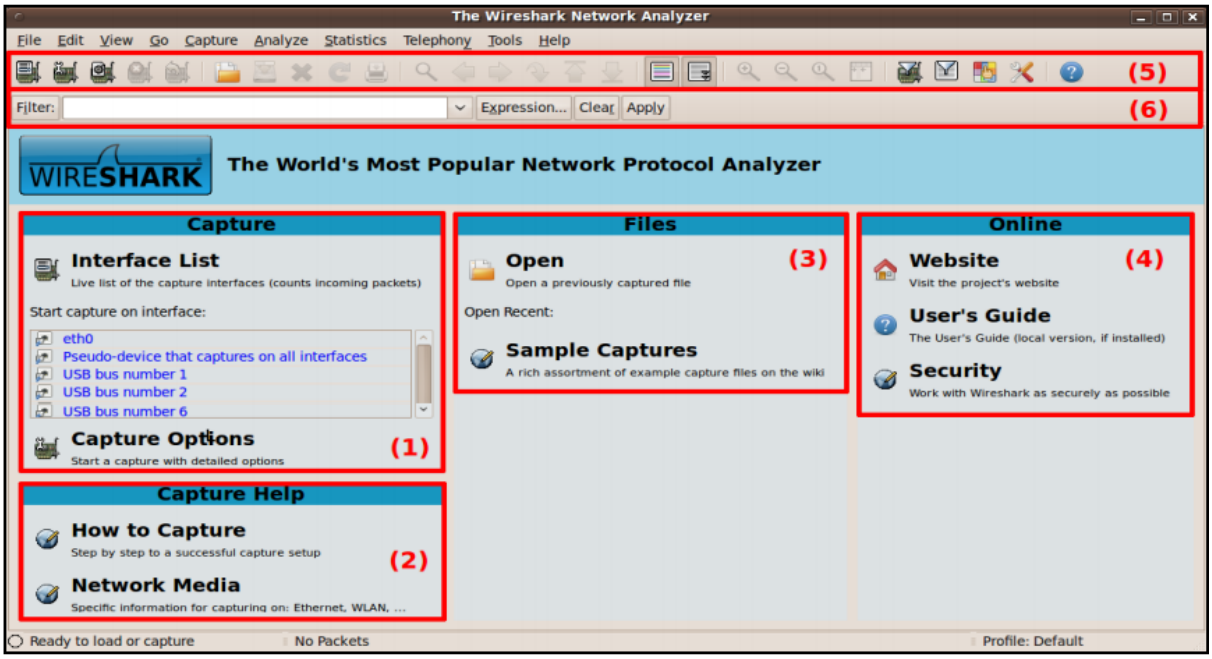
Chapitre 2 Capture réseau avec Wireshark

2.1 Introduction

Wireshark est un logiciel d'analyse réseau (sniffer) qui permet de visualiser l'ensemble des données transitant sur la machine qui l'exécute, et d'obtenir des informations sur les protocoles applicatifs utilisés.

De nombreuses distributions linux incluent Wireshark dans leur gestionnaire de paquet. Ainsi sous ubuntu on tapera simplement sudo apt-get install wireshark.

2.2 Lancement de Wireshark



L'utilitaire s'ouvre sur l'interface présentée en Figure 1, découpée en quatre zones :

- (1) liste des interfaces et lancement rapide d'une capture
- (2) Aide sur la capture de paquets
- (3) Analyse d'une capture précédente enregistrée sur fichier
- (4) Aide online et manuel utilisateur

La principale utilisation que nous ferons de Wireshark consistera en la capture de trames réseau en live. Les trois premiers boutons de la barre d'icônes permettent une telle capture, et sont des raccourcis aux éléments présentés dans le menu « capture »

Pour lancer une capture live, plusieurs méthodes s'offrent à nous. Nous pouvons:

- Cliquer sur la première icône de la barre des icônes intitulée liste des interfaces de captures disponibles. Une fenêtre s'ouvre (Figure 2) , il nous suffit alors de cliquer sur

le bouton « Start » de l'interface de notre choix pour lancer la capture sur cette interface.

Figure 2: Liste des interfaces, menu « capture / interfaces », ou premier icône

Une fois lancée, la capture peut être interrompue en cliquant sur « Stop »

Lorsqu'une capture est active, le logiciel présente l'interface de l'analyseur (Figure 3). Cette interface reste ensuite visible lorsque la capture est arrêtée.

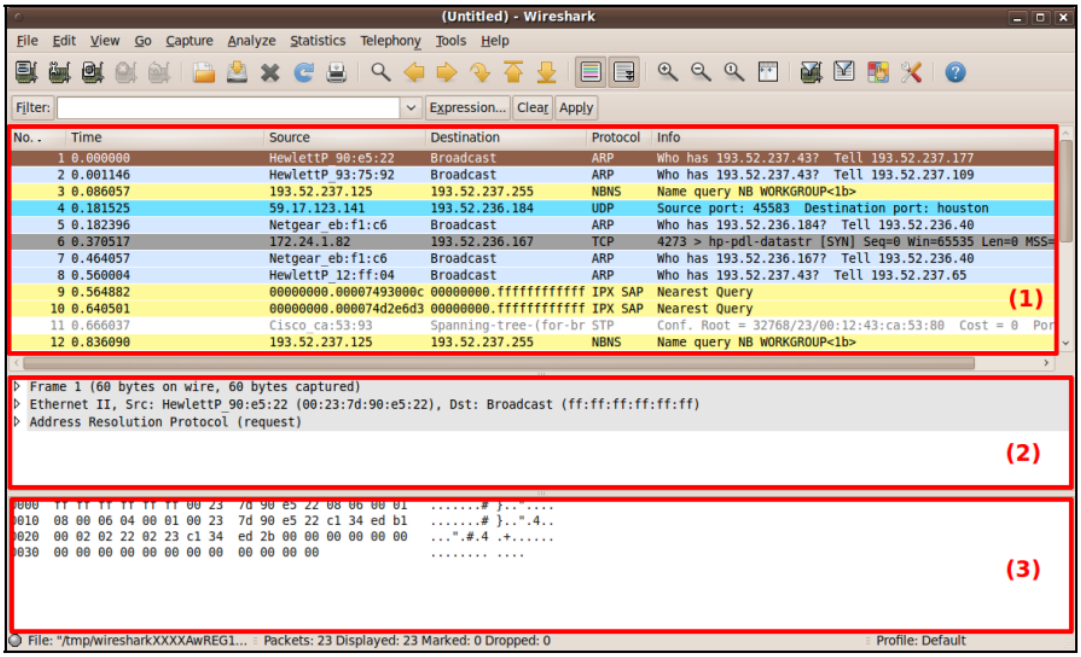


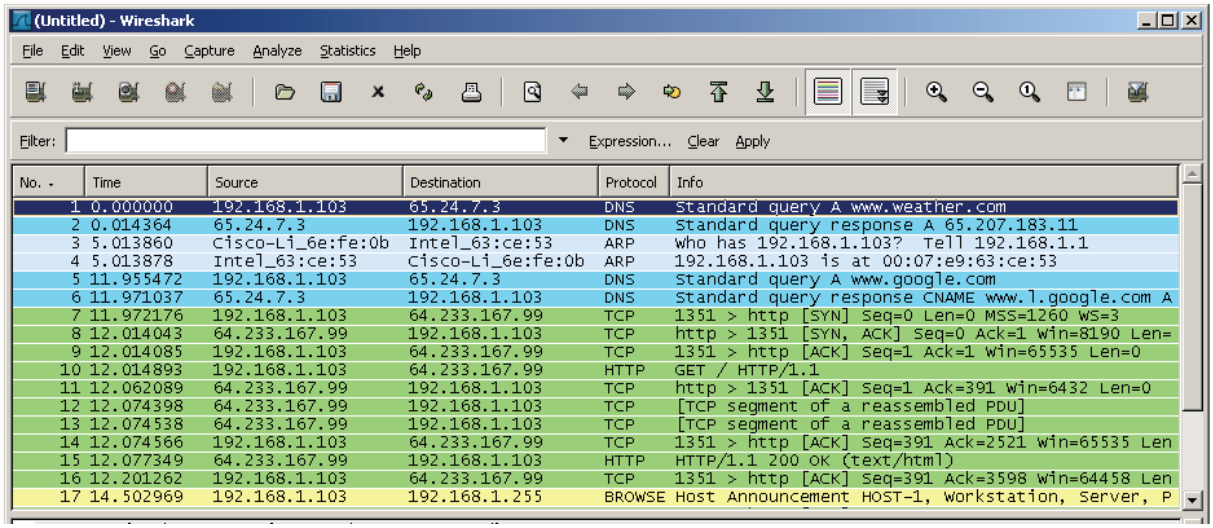
Figure 3: interface de l'analyseur

L'interface de l'analyseur est découpée en trois zones :

- Zone supérieure, numérotée (1) sur Figure 3 : liste l'ensemble des paquets capturés
- Zone centrale, numérotée (2) sur Figure 3 : affiche le détail d'un paquet sélectionné dans la liste des paquets de la zone supérieure. Les informations présentées y sont de loin les plus pertinentes, puisqu'il est possible de visualiser aisément les différents en-têtes résultant de l'encapsulation d'un message.
- Zone inférieure, numérotée (3) sur Figure 3 : présente l'ensemble du paquet sous forme hexadécimale et ASCII. Ces octets contiennent les en-têtes des différentes couches de l'architecture TCP/IP ainsi que les données transmises par le processus à l'origine du message.

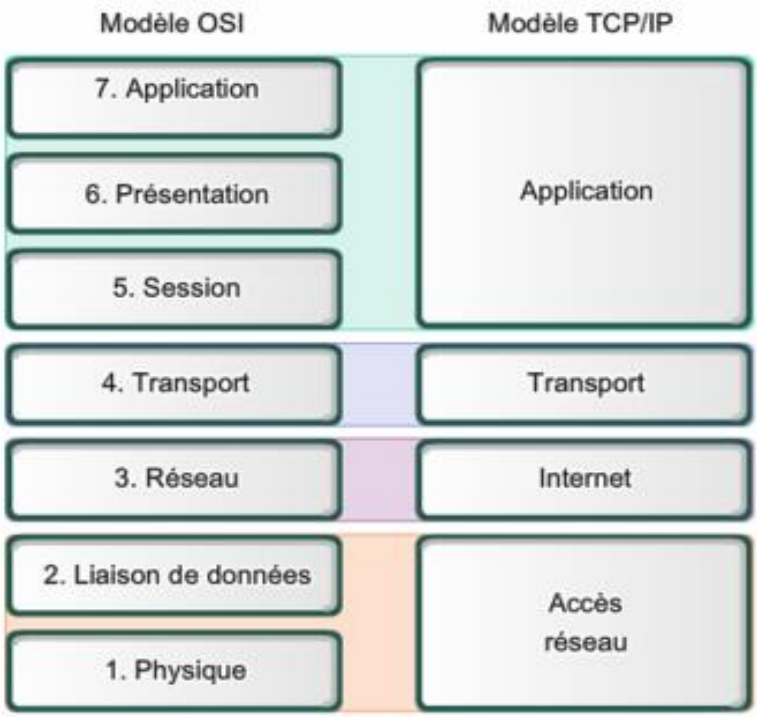
2.3 Analyse des informations de trafic Web

Si vous disposez d'une connexion Internet, ouvrez un navigateur et accédez au site www.google.com. Réduisez la fenêtre Google et revenez dans Wireshark. Le trafic capturé qui s'affiche doit être similaire à celui illustré ci-dessous. Dans la fenêtre Wireshark, localisez les colonnes **Source, Destination et Protocol.**



2.4 Analyse d'un paquet : Encapsulation d'un paquet

2.4.1 Rappel



Lorsqu'un paquet est sélectionné, la zone centrale permet de visualiser clairement les

différentes couches d'encapsulation du paquet. Par exemple si l'on sélectionne un paquet de type UDP , la zone centrale pourrait afficher quelque chose de similaire à ce qui est présenté Figure 4.

Les 5 entrées présentées correspondent à différentes encapsulations, ordonnées de la couche la plus basse à la couche la plus haute :

1. Données sur le média de capture (physique)
2. Trame relative à la couche liaison de donnée : Ethernet II sur Figure 4
3. Paquet relatif à la couche réseau : Internet Protocol sur Figure 4
4. Datagramme relatif à la couche transport : User Datagram Protocol sur Figure 4
5. Données de l'application : regroupe généralement les couches session, présentation, Application.

```
▷ Frame 5765 (65 bytes on wire, 65 bytes captured)
▷ Ethernet II, Src: Dell_b3:04:ee (00:1d:09:b3:04:ee), Dst: CompalIn_41:3e:16 (00:1b:38:41:3e:16)
▷ Internet Protocol, Src: 193.52.236.243 (193.52.236.243), Dst: 193.52.236.247 (193.52.236.247)
▷ User Datagram Protocol, Src Port: 55056 (55056), Dst Port: terabase (4000)
▷ Data (23 bytes)
```

Figure 4:Encapsulation d'un paquet UDP, zone centrale de l'analyseur.

Pour tout item correspondant à un niveau d'encapsulation, un clic sur le triangle en début de ligne permet de dérouler l'en-tête afin de voir l'ensemble des champs le composant. Certains champs peuvent également être déroulés. Sur l'exemple présenté en Figure 5, nous avons étendu les entrées correspondant aux couches réseau, transport et application en cliquant sur les triangles correspondants. Nous pouvons voir entre autres que :

- Le paquet est de type IP v4 : ref (2) sur Figure 5
- Le type de données de ce paquet IP est un datagramme UDP : ref (5) sur Figure 5
- L'ip de la machine source est 193.52.236.243 : ref (6) sur Figure 5

```
▷ Frame 5765 (65 bytes on wire, 65 bytes captured) (1)
▷ Ethernet II, Src: Dell_b3:04:ee (00:1d:09:b3:04:ee), Dst: CompalIn_41:3e:16 (00:1b:38:41:3e:16)
▽ Internet Protocol, Src: 193.52.236.243 (193.52.236.243), Dst: 193.52.236.247 (193.52.236.247)
    Version: 4 (2)
    Header length: 20 bytes (3)
  ▷ Differentiated Services Field: 0x00 (DSCP 0x00: Default; ECN: 0x00)
    Total Length: 51 (4)
    Identification: 0x0000 (0)
  ▷ Flags: 0x04 (Don't Fragment)
    Fragment offset: 0
    Time to live: 64
    Protocol: UDP (0x11) (5)
  ▷ Header checksum: 0xde65 [correct]
    Source: 193.52.236.243 (193.52.236.243) (6)
    Destination: 193.52.236.247 (193.52.236.247) (7)
▽ User Datagram Protocol, Src Port: 55056 (55056), Dst Port: terabase (4000)
    Source port: 55056 (55056)
    Destination port: terabase (4000)
    Length: 31 (8)
  ▷ Checksum: 0x5c85 [validation disabled]
▽ Data (23 bytes) (9)
    Data: 74657374206427656E766F69206465206D657373616765
    [Length: 23]

0000  00 1b 38 41 3e 16 00 1d  09 b3 04 ee 08 00 45 00   ..8A>... ......E.
0010  00 33 00 00 40 00 40 11  de 65 c1 34 ec f3 c1 34   .3..@.@. .e.4...4 (10)
0020  ec f7 d7 10 0f a0 00 1f  5c 85 74 65 73 74 20 64   ........ \.test d
0030  27 65 6e 76 6f 69 20 64  65 20 6d 65 73 73 61 67   'envoi d e messag (11)
0040  65                                                 e
```

Figure 5: Visualisation détaillée des en-tetes d'un paquet

2.4.2 Détail du paquet

- L'ip de la machine destination est 193.52.236.247 : ref (7) sur Figure 5
- Nous pouvons également faire un point sur la taille des données et des en-têtes à différents niveaux d'encapsulation :
- La taille des données envoyée par le processus est de 23 octets : ref (9) sur Figure 5
- La taille totale du datagramme UDP est de 31 octets - ref (8) sur Figure 5 - .
- Cette valeur est la somme entre la taille réelle des données (23 octets) et 8 octets d'en-tête du paquet (8 étant une valeur fixe pour un paquet UDP)
- La taille des en-têtes du paquet IP est de 20 octets : ref (3) sur Figure 5
- Le paquet IP contient un en-tête (20 octets) ainsi que le datagramme UDP (31 octets). Sa taille totale est de 51 octets, taille rappelée en ref (4) sur Figure 5
- La taille totale du paquet IP. Cette valeur somme la taille du paquet
- UDP à la taille de l'en-tête IP.
- Si l'on ajoute **14** octets d'en-tête pour la couche Ethernet II (taille fixe), la taille totale de la trame est de 65 octets, comme présentée en ref (1) sur Figure 5.

Notons ainsi que pour transférer 23 octets de données brutes, il nous a fallu transférer au total 65 octets (en fait il nous a même fallu transférer des octets supplémentaires avant la trame Ethernet. Ces octets seront ici passés sous silence).

2.4.3 Visualisation hexadécimale de la trame

La zone inférieure permet de visualiser la trame capturée sous forme hexadécimale.

Pour n'importe quel niveau, un clic sur une valeur de champs permet de visualiser la portion d'octets correspondant à cette valeur dans le paquet au niveau de la zone inférieure de l'analyseur.

Réciproquement, un clic sur un octet quelconque affiche le champ correspondant dans la zone centrale. Ainsi dans l'exemple présenté en figure Figure 5, un clic sur le champ « Source » de la couche réseau - voir ref (6) sur Figure 5 - mettra en évidence dans la zone inférieure les octets codant cette source - voir ref (10) sur Figure 5 - et réciproquement.

Signalons enfin qu'il est possible de visualiser les données transmises dans ce datagramme UDP. En cliquant sur l'entrée « Data » de la zone centrale, les octets correspondants mais également leur codage ASCII seraient mis en évidence dans la zone inférieure. En examinant ce codage ASCII, il est parfois très facile de décoder les messages.

Si l'on examine les derniers caractères ASCII représentant le message - ref (11) sur Figure 5 - on devine aisément que le message envoyé était « test d'envoi de message ».

2.4.4 Principe et mise en place d'un filtre

L'intégralité des paquets capturés est listée dans la zone supérieure de l'analyseur. Il est souvent utile de filtrer les paquets à capturer, afin de pouvoir visualiser correctement un certain type de paquets seulement.

Wireshark permet de filtrer les paquets à capturer en fonction des informations des différentes couches d'encapsulation.

La mise en place d'un filtre s'effectue par le biais d'une règle de filtre à définir dans la zone « filtre » de l'analyseur. Une règle de filtre est constituée d'un ensemble de tests d'expressions impliquant des noms de champs et des valeurs. Un paquet n'est alors listé qu'à la condition qu'il satisfasse les conditions du filtre.

Nous terminerons ce tutoriel en énonçant quelques filtres possibles :

Désignation	**Filtre associé :**
Segments TCP uniquement	tcp
Paquets relatifs à TCP uniquement	ip.proto == 0x06
Adresse ip 192.168.0.1 ou 192.168.1.5	ip.addr == 192.168.0.1 || ip.addr == 192.168.1.5
Trafic HTTP uniquement	http
Segment TCP sauf sur port 80	tcp && !(tcp.port == 80)
Adresse Ethernet 00:FF:12:34:AE:FF	eth.addr == 00:FF:12:34:AE:FF
Trafic 192.168.0.1 vers 197.168.10.5	ip.src == 192.168.0.1 && ip.dst == 197.168.10.5
Trafic UDP entre ports 40 et 67	udp && udp.port >= 40 && udp.port <=67
Trafic MSN	tcp && tcp.port ==1863

Chapitre 3 Attaques cryptographiques

3.1 Introduction

Un **exploit** est un programme informatique conçu pour l'exploitation d'une vulnérabilité. Un exploit est spécifique à une version d'une application. On distingue deux types d'exploits :

- Augmentation des privilèges : Les exploits les plus dangereux permettent d'avoir les privilèges d'administrateur (root) ;
- Provocation d'une erreur système : Certains exploits ont pour objectif de faire planter le système.

Exemple de site répertoriant les outils : http://www.insecure.org ;

Top 10 Web Application Security Risks

OWASP Top Ten | OWASP Foundation

Note : La plupart du temps les exploits sont écrits en langage C ou en Perl.

3.2 Attaques cryptographiques

3.2.1 Les mots de passe

Lors de la connexion à un système informatique, celui-ci demande la plupart du temps un identifiant (login ou username) et un mot de passe (password) pour y accéder.

Si les données sur le compte de l'utilisateur n'ont pas un caractère stratégique, l'accès au compte de l'utilisateur peut constituer une porte ouverte vers le système tout entier.

- Dès qu'un pirate obtient un accès à un compte d'une machine, il lui est possible d'élargir son champ d'action en obtenant la liste des utilisateurs autorisés à se connecter à la machine.
- A l'aide d'outils de génération de mots de passe, le pirate peut essayer un grand nombre de mots de passe générés aléatoirement ou à l'aide d'un dictionnaire (éventuellement une combinaison des deux). S'il trouve par hasard le mot de passe de l'administrateur, il obtient alors toutes les permissions sur la machine !
- De plus, à partir d'une machine du réseau, le pirate peut éventuellement obtenir un accès sur le réseau local, ce qui signifie qu'il peut dresser une cartographie des autres serveurs côtoyant celui auquel il a obtenu un accès.

La plupart des systèmes sont configurés de manière à bloquer temporairement le compte d'un utilisateur après un certain nombre de tentatives de connexion infructueuses. En contrepartie, un pirate peut se servir de ce mécanisme d'auto-défense pour bloquer l'ensemble des comptes utilisateurs afin de provoquer un déni de service. Sur la plupart des systèmes les mots de passe sont stockés de manière chiffrée (ou cryptée) dans un fichier ou une base de données. Le pirate peut tenter de casser le mot de passe d'un utilisateur en particulier ou bien de l'ensemble des comptes utilisateurs.

On appelle “**attaque par force brute**” ou attaque exhaustive (brute force cracking) le cassage d'un mot de passe en testant tous les mots de passe possibles.

- Il existe un grand nombre d'outils, pour chaque système d'exploitation, permettant de réaliser ce genre d'opération.
- Ces outils servent aux administrateurs système à éprouver la solidité des mots de passe de leurs utilisateurs mais leur usage est détourné par les pirates informatiques pour s'introduire dans les systèmes informatiques.

Note: Les outils d'attaque par force brute peuvent demander des heures, voire des jours, de calcul même avec des machines équipées de processeurs puissants.

La plupart du temps les utilisateurs choisissent des mots de passe ayant une signification réelle (un prénom, une couleur, le nom d'un animal…). Essayant ces mots pour casser le mot de passe s’appelle une **attaque par dictionnaire**.

Une “**attaques hybrides**”, vise particulièrement les mots de passe constitué d'un mot traditionnel et suivi d'une lettre ou d'un chiffre (tel que mohamed12,50). Il s'agit d'une combinaison d'attaque par force brute et d'attaque par dictionnaire.

Il existe des moyens permettant au pirate d'obtenir les mots de passe des utilisateurs :

- Les key loggers (enregistreurs de touches), sont des logiciels qui, lorsqu'ils sont installés sur le poste de l'utilisateur, permettent d'enregistrer les frappes de claviers saisies par l'utilisateur. Les systèmes d'exploitation récents possèdent des mémoires tampon protégées permettant de retenir temporairement le mot de passe et accessibles uniquement par le système.
- L'ingénierie sociale consiste à exploiter la naïveté des individus pour obtenir des informations.
- L'espionnage représente la plus vieille des méthodes. Il suffit en effet parfois à un pirate d'observer les papiers autour de l'écran de l'utilisateur ou sous le clavier afin d'obtenir le mot de passe.

Choix du mot de passe :Un mot de passe de 4 chiffres correspond à 10 000 possibilités (10^4). On lui préfèrera un mot de passe de 4 lettres, pour lequel il existe 456972 possibilités (26^4). Un mot de passe mêlant chiffres et lettres, voire également des majuscules et des caractères spéciaux sera encore plus difficile à casser.

Mots de passe à éviter :

- votre identifiant
- votre nom
- votre prénom ou celui d'un proche (conjoint, enfant, etc.) ;
- un mot du dictionnaire ;
- un mot à l'envers (les outils de cassage de mots de passe prennent en compte cette possibilité) ;

- un mot suivi d'un chiffre, de l'année en cours ou d'une année de naissance (password1999).

Il n'est pas sain d'avoir un seul mot de passe, au même titre qu'il ne serait pas sain d'avoir comme code de carte bancaire le même code que pour son téléphone portable et que le digicode en bas de l'immeuble.

Note : Il est conseillé de posséder plusieurs mots de passe par catégorie d'usage, en fonction de la confidentialité du secret qu'il protège (carte bancaire, messagerie…).

Politique en matière de mot de passe: Toute entreprise souhaitant garantir un niveau de sécurité optimal se doit de mettre en place une réelle politique de sécurité de matière de mots de passe. Il s'agit d'imposer aux employés le choix d'un mot de passe conforme à certaines exigences, par exemple :

- Une longueur de mot de passe minimale
- La présence de caractères particuliers
- Un changement de casse (minuscule et majuscules)

Il est possible de renforcer cette politique de sécurité en imposant une durée d'expiration des mots de passe, afin d'obliger les utilisateurs à modifier régulièrement leur mot de passe.

Il est recommandé aux administrateurs système d'utiliser des logiciels de cassage de mots de passe en interne sur les mots de passe de leurs utilisateurs afin d'en éprouver la solidité.

3.2.2 Attaque man in the middle

L'attaque “man in the middle” (attaque de l'homme au milieu ou MITM) est un scénario d'attaque dans lequel un pirate écoute une communication entre deux interlocuteurs et falsifie les échanges afin de se faire passer pour l'une des parties.

La plupart des attaques de type MITM consistent à écouter le réseau à l'aide d'un outil appelé sniffer.

3.2.3 Attaque par rejeu

Les attaques par rejeu (replay attaque) sont des attaques de type MITM consistant à intercepter des paquets de données et à les retransmettre tels quel (sans aucun déchiffrement) au serveur destinataire.

Le pirate peut bénéficier des droits de l'utilisateur. Imaginons un scénario dans lequel un client transmet un nom d'utilisateur et un mot de passe chiffrés à un serveur afin de s'authentifier. Si un pirate intercepte la communication et rejoue la séquence, il obtiendra alors les mêmes droits que l'utilisateur. Si le système permet de modifier le mot de passe, il pourra même en mettre un autre, privant ainsi l'utilisateur de son accès.

3.2.4 Introduction aux attaques par déni de service

Une attaque par déni de service (Denial of Service, DoS) est un type d'attaque visant à rendre indisponible pendant un temps indéterminé les services ou ressources d'une organisation. Il

s'agit la plupart du temps d'attaques à l'encontre des serveurs d'une entreprise, afin qu'ils ne puissent être utilisés et consultés.

Le but d'une telle attaque n'est pas de récupérer ou d'altérer des données, mais de **nuire** à la réputation de sociétés ayant une présence sur internet.

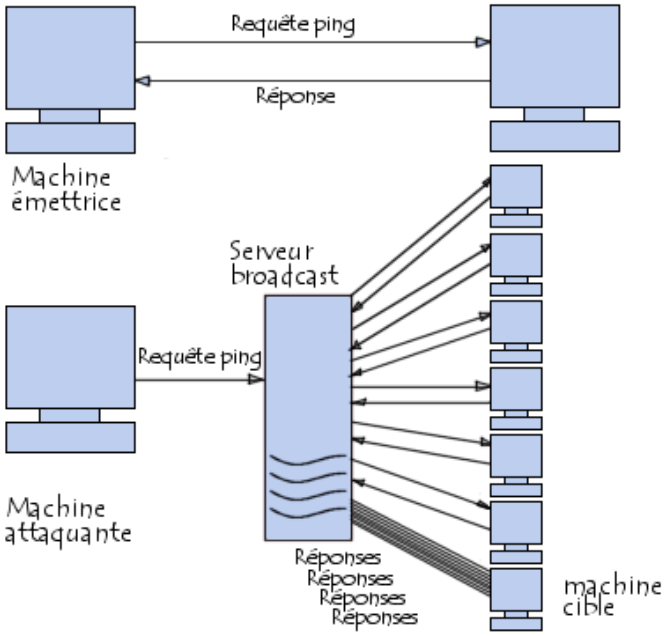
Le principe des attaques par déni de service consiste à envoyer des paquets IP ou des données de taille ou de constitution inhabituelle, afin de provoquer une saturation ou un état instable des machines victimes. Lorsqu'un déni de service est provoqué par plusieurs machines, on parle alors de “déni de service distribué” (Distributed Denial of Service, DDOS). Les attaques par déni de service distribué les plus connues sont Tribal Flood Network et Trinoo.

Pour se protéger de ce type d'attaque, il est nécessaire de mener une veille active sur les nouvelles attaques et vulnérabilités.

La technique dite par réflexion

La technique dite “attaque par réflexion”(smurf) est basée sur l'utilisation de serveurs de diffusion (broadcast) pour paralyser un réseau. Un serveur broadcast est un serveur capable de dupliquer un message et de l'envoyer à toutes les machines présentes sur le même réseau. Le scénario d'une telle attaque est le suivant :

- la machine attaquante envoie une requête ping à un ou plusieurs serveurs de diffusion en falsifiant l'adresse IP source et en fournissant l'adresse IP d'une machine cible.
- le serveur de diffusion répercute la requête sur l'ensemble du réseau ;
- toutes les machines du réseau envoient une réponse au server de diffusion,
- le serveur broadcast redirige les réponses vers la machine cible.



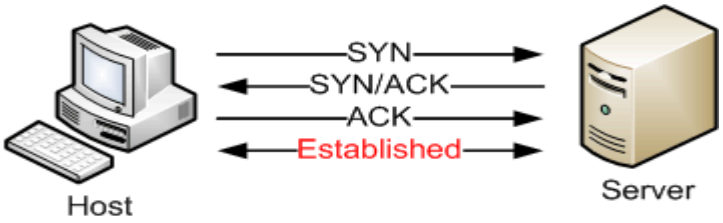
Attaque SYN

- L' "attaque SYN" (pour synchronize) est une attaque par saturation (déni de service) exploitant le mécanisme de poignéee de main en trois temps (Three-ways handshake) du protocole TCP.

Dans une connexion TCP, le client envoie une requête SYN(étape 1), le serveur répond par un paquet SYN/ACK (étape 2) et le client enfin valide la connexion par un paquet ACK (étape 3) .

Un client malveillant peut annuler l'étape 3 et ne pas répondre (par le message ACK). Le serveur attend un certain temps avant de libérer les ressources qui ont été réservées pour le client (Il existe un mécanisme d'expiration permettant de rejeter les paquets au bout d'un certain délai).

Après l'étape 2, la connexion est semi-ouverte et consomme un certain nombre de ressources du côté du serveur (mémoire, temps processeur, etc.). En générant suffisamment de connexions incomplètes de ce type, il est possible de surcharger les ressources du serveur et ainsi d'empêcher le serveur d'accepter de nouvelles requêtes, avec pour résultat un déni de service.

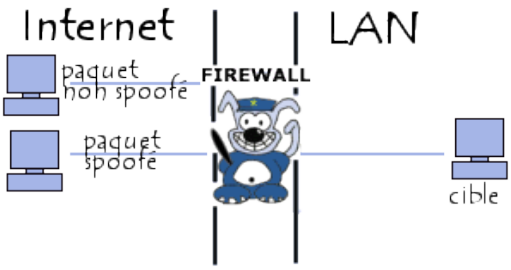


L'usurpation d'adresse IP

L' "usurpation d'adresse IP" (spoofing IP) est une technique consistant à modifier l'adresse IP de l'expéditeur d'un paquet IP par l'adresse IP d'une autre machine.

Cette attaque peut permettre à un pirate de faire passer des paquets sur un réseau sans que ceux-ci ne soient interceptés par le système de filtrage de paquets (pare-feu).

- un pare-feu (firewall) fonctionne la plupart du temps grâce à des règles de filtrage indiquant les adresses IP autorisées à communiquer avec les machines internes au réseau.
- Un paquet spoofé avec l'adresse IP d'une machine interne semblera provenir du réseau interne et sera relayé à la machine cible.



Modification de l'en-tête TCP : les données circulent grâce au protocole IP, qui assure l'encapsulation des données dans des structures appelées datagramme IP (paquet).

Voici la structure d'un datagramme IP:

Version	Longueur d'en-tête	Type de service	Longueur totale	
Identification			Drapeau	Décalage fragment
Durée de vie		Protocole	Somme de contrôle en-tête	
Adresse IP source				
Adresse IP destination				
Données				

Usurper une adresse IP revient à changer le champ source afin de simuler un datagramme provenant d'une autre adresse IP. Cependant, les paquets sont généralement transportés par le protocole TCP, qui assure une transmission dite “fiable”.

Les liens d'approbation : Le protocole TCP permet, au niveau des applications, de gérer les données en provenance (ou à destination) de la couche inférieure du modèle OSI (Open Systems Interconnection).

Le protocole TCP permet d'assurer le transfert des données de façon fiable grâce à un système d'accusés de réception (ACK) permettant au client et au serveur de s'assurer de la bonne réception mutuelle des données.

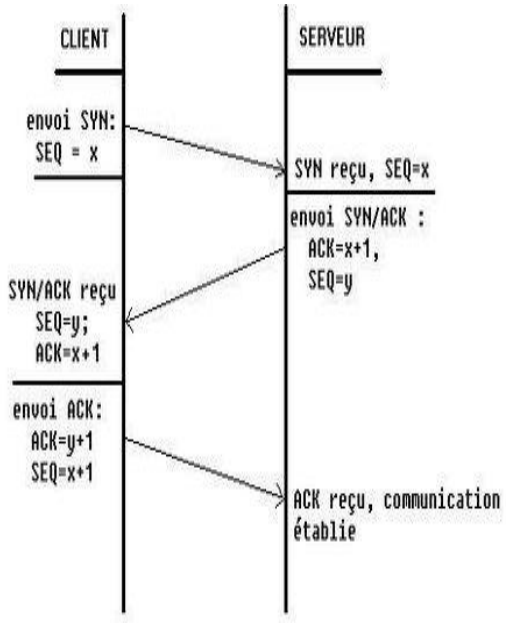
Les datagrammes IP encapsulent des paquets TCP dont voici la structure :

0 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15								16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31
Port Source								Port destination
Numéro d'ordre								
Numéro d'accusé de réception								
Décalage données	réservée	URG	ACK	PSH	RST	SYN	FIN	Fenêtre
Somme de contrôle								Pointeur d'urgence
Options								Remplissage
Données								

Lors de l'émission d'un paquet, une séquence (numéro d'ordre) est associé, et un échange de paquets contenant des champs particuliers (drapeaux) permet de synchroniser le client et le serveur.

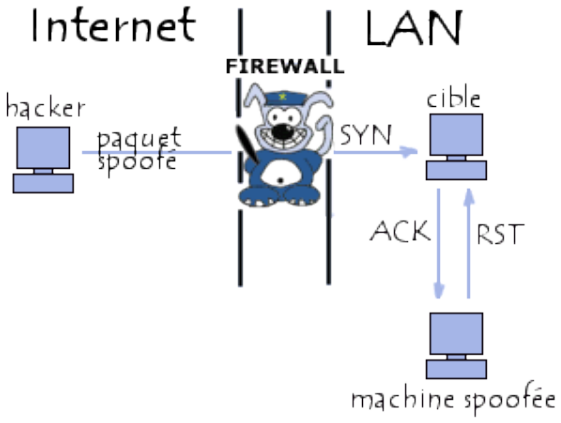
Ce dialogue permet d'initier la connexion, il se déroule en trois temps:

- Dans une première étape, le client transmet un segment dont le drapeau SYN est à 1, avec un numéro d'ordre X.
- Dans une deuxième étape, le serveur envoie au client un segment dont le drapeau ACK est non nul et le drapeau SYN est à 1 (synchronisation). Le champ le plus important de ce segment est le champ ACK qui contient le numéro d'ordre initial du client, incrémenté de 1.
- Enfin, le client envoie au serveur un segment dont le drapeau ACK est non nul, et dont le drapeau SYN est à zéro (pas de synchronisation). Son numéro d'ordre est incrémenté et le numéro d'accusé de réception (ACK) représente le numéro de séquence initial du serveur incrémenté de 1.



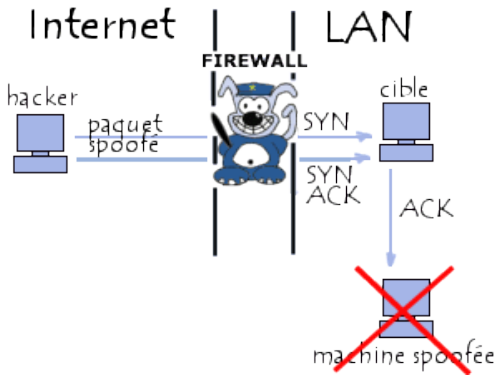
Annuler la connexion de la machine spoofée : Dans le cadre d'une attaque par usurpation d'adresse IP, la machine spoofée va répondre avec un paquet TCP dont le drapeau RST (reset) est non nul, ce qui mettra fin à la connexion.

Le hacker n'a aucune information des réponses de la machine cible qui vont vers une autre machine du réseau (blind attack).



Ainsi, la machine spoofée prive le pirate de toute tentative de connexion, car elle envoie systématiquement un drapeau RST à la machine cible. Le travail du hacker consiste alors à invalider la machine spoofée en la rendant injoignable pendant toute la durée de l'attaque.

Prédire les numéros de séquence: Une fois la machine spoofée est invalidée, la machine cible attend un paquet contenant le ACK et le bon numéro de séquence. Tout le travail de l'attaquant consiste à "deviner" le numéro de séquence (du serveur). Pour cela, généralement les pirates utilisent le champ option de l'en-tête IP afin d'indiquer une route de retour spécifique pour le paquet. Grâce au sniffing, le pirate sera à même de lire le contenu des trames de retour...



En connaissant le dernier numéro de séquence émis (par le serveur), l'attaquant établit des statistiques concernant son incrémentation et envoie des message ACK jusqu'à obtenir le bon numéro de séquence.

Détournement de session (TCP session hijacking)

- **Le vol de session TCP** : C' est une technique consistant à intercepter une session TCP initiée entre deux machine afin de la détourner.
    - L' authentification s'effectue uniquement à l'ouverture de la session, un attaquant réussissant cette attaque parvient à prendre possession de la connexion pendant toute la durée de la session.
- **Source-routing :** La technique de détournement initiale consistait à utiliser l'option source routing du protocole IP. Cette option permettait de préciser le chemin à suivre pour les paquets IP, à l'aide d'une série d'adresses IP indiquant les routeurs à utiliser.
    - Le pirate peut indiquer un chemin de retour pour les paquets vers un routeur sous son contrôle.
- **Attaque à l'aveugle :** Lorsque le source-routing est désactivé, une deuxième méthode consiste à envoyer des paquets à l'aveugle (blind attack), sans recevoir de réponse, en essayant de deviner les numéros de séquence.
- **Man in the middle :** Situant sur le même réseau que les deux machines, le pirate peut écouter le réseau et de "faire taire" l'une des machines en saturant le réseau afin de prendre sa place.

ARP poisoning

- Cette attaque est de type man in the middle. elle consiste à exploiter une faiblesse du protocole ARP (Address Resolution Protocol) dont l'objectif est de permettre de retrouver l'adresse IP d'une machine connaissant l'adresse physique (adresse MAC) de sa carte réseau.
- L'objectif de l'attaque consiste à s'interposer entre deux machines du réseau et de transmettre à chacune un paquet ARP falsifié précisant que l'adresse MAC de l'autre machine a changé, l'adresse MAC fournie étant celle de l'attaquant.
- Ainsi, les deux machines cibles vont mettre à jour leur table dynamique appelée Cache ARP. À chaque fois qu'une des deux machines souhaitera communiquer avec la machine distante, les paquets seront envoyés à l'attaquant, qui les transmettra de manière transparente à la machine destinatrice.

Ecoute réseau

- **L'analyse de réseau :** Un “analyseur réseau”(sniffer) est un dispositif permettant de capturer les informations qui circulent dans un réseau.
    - Dans une utilisation normale les machines ignorent les paquets qui ne leur sont pas destinés. Utilisant l'interface réseau dans un mode spécifique (appelé généralement mode promiscuous) il est possible d'écouter tout le trafic passant par un adaptateur réseau (une carte réseau ethernet, une carte réseau sans fil, etc.).
- **Utilisation du sniffer :** Un sniffer est un outil permettant d'étudier le trafic d'un réseau.
    - Généralement il sert aux administrateurs pour diagnostiquer les problèmes sur leur réseau ainsi que pour connaître le trafic qui y circule.
- Comme tous les outils d'administration, le sniffer peut également servir à un attaquant ayant un accès physique au réseau pour collecter des informations.
    - Ce risque est plus important sur les réseaux sans fils car il est difficile de confiner les ondes hertziennes dans un périmètre délimité, si bien que des personnes malveillantes peuvent écouter le trafic en étant simplement dans le voisinage.

La grande majorité des protocoles Internet font transiter les informations en clair (non chiffrée). Lorsqu'un utilisateur du réseau consulte sa messagerie via le protocole POP ou IMAP, ou bien surfe sur internet sur des sites dont l'adresse ne commence pas par HTTPS, toutes les informations envoyées ou reçues peuvent être interceptées. Des sniffers spécifiques ont été mis au point par des pirates afin de récupérer les mots de passe circulant dans le flux réseau.

Exemple de sniffer:

- Wireshark

- TCPdump

- WinDump

Balayage de port (port scanning)

- **Le balayage de ports** : Un scanner est un utilitaire permettant un balayage des ports ouverts (port scanning) sur une machine donnée ou sur un réseau tout entier.
- **Fonctionnement d'un scanner :** Un scanner est capable de déterminer les ports ouverts sur un système en envoyant des requêtes successives sur les différents ports et analyse les réponses afin de déterminer lesquels sont actifs.
- En analysant la structure des paquets TCP/IP reçus, les scanners évolués sont capables de déterminer le système d'exploitation de la machine distante ainsi que les versions des applications associées aux ports**.**

On distingue habituellement deux méthodes :

- L'acquisition active d'informations consistant à envoyer un grand nombre de paquets possédant des en-têtes caractéristiques et la plupart du temps non conformes aux recommandations et à analyser les réponses afin de déterminer la version de l'application utilisée. En effet, chaque application implémente les protocoles d'une façon légèrement différente, ce qui permet de les distinguer.
- L'acquisition passive d'informations. Son principe de fonctionnement est proche, si ce n'est qu'il consiste à analyser les champs des datagrammes IP circulant sur un réseau, à l'aide d'un sniffer. Ce type d'analyse est ainsi très difficile à détecter.

Quelque scanners:

- Nessus

- Nmap ("Network Mapper") - Utilitaire libre d'audits de sécurité et d'exploration des réseaux

Débordement du tampon (buffer overflow)

Les attaques par “débordement de tampon” ont pour objectif l'exécution de code arbitraire par un programme en lui envoyant plus de données qu'il n'est censé en recevoir.

Exemple : les programmes stockent les données provisoirement dans une zone de la mémoire appelée tampon. certaines fonctions de lecture, telles que les fonctions strcpy() du langage C, ne gèrent pas ce type de débordement et provoquent un plantage de l'application pouvant aboutir à l'exécution du code arbitraire et ainsi donner un accès au système.

Pour se protéger de ce type d'attaque, il faut développer des applications à l'aide de langages de programmation évolués, assurant une gestion fine de la mémoire allouée ou bien à l'aide de langage de bas niveau en utilisant des bibliothèques de fonctions sécurisées (par exemple les fonctions strncpy()).

Spam

Le terme **spam** signifie l'envoi massif de courrier électronique (souvent de type publicitaire) à des destinataires ne l'ayant pas sollicité et dont les adresses ont généralement été récupérées sur internet. Le but premier du spam est de faire de la publicité à moindre prix.

Les spammeurs cherchent des adresses électroniques sur internet (dans les forums, sur les sites internet, dans les groupes de discussion, etc.) grâce à des logiciels, appelés **robots**,

parcourant les différentes pages et stockant au passage dans une base de données toutes les adresses électroniques y figurant. Il ne reste ensuite au spammeur qu'à lancer une application envoyant successivement à chaque adresse le message publicitaire.

Inconvénients :

- l'espace qu'il occupe dans les boîtes aux lettres des victimes ;
- la perte de temps occasionnée par le tri et la suppression des messages non sollicités;
- le caractère violant ou dégradant des textes ou images véhiculés par ces messages, pouvant heurter la sensibilité des plus jeunes;
- la bande passante qu'il gaspille sur le réseau.

Le spam génère des coûts de gestion supplémentaires pour les fournisseurs d'accès à internet (FAI), se répercutant sur le coût de leurs abonnements. Ce surcoût est notamment lié à :

- la mise en place des systèmes antispam;
- la sensibilisation des utilisateurs;
- la formation du personnel;
- la consommation de ressources supplémentaires (serveurs de filtrage, etc.).

Il existe des dispositifs antispam permettant de repérer et de supprimer les messages indésirables sur la base de règles évoluées. On distingue généralement deux familles de logiciels antispam :

- Les dispositifs antispam côté client : Il s'agit généralement de systèmes possédant des filtres permettant d'identifier, sur la base de règles prédéfinies ou d'un apprentissage (filtres bayésiens).
- Les dispositifs antispam côté serveur, permettant un filtrage du courrier avant remise aux destinataires. Ce type de dispositif est le meilleur car il permet de stopper le courrier non sollicité en amont et éviter l'engorgement des réseaux et des boîtes aux lettres.

Pour éviter le spam, il est nécessaire de divulguer son adresse électronique le moins possible et à ce titre :

- Ne pas relayer les messages (blagues, etc.) invitant l'utilisateur à transmettre le courrier au maximum de contacts possible. De telles listes sont effectivement des aubaines pour les collecteurs d'adresses. Il est éventuellement possible de faire suivre le message en s'assurant de masquer les adresses des destinataires précédents.
- Eviter au maximum de publier son adresse électronique sur des forums ou des sites internet.
- Créer une ou plusieurs “adresses-jetables” servant uniquement à s'inscrire ou s'identifier sur les sites jugés non dignes de confiance.

mail bombing

Le mail bombing consiste à transmettre plusieurs milliers de messages identiques à une boîte aux lettres électronique afin de la saturer.

Les mails sont stockés sur un serveur de messagerie, jusqu'à ce qu'ils soient relevés par le propriétaire du compte de messagerie. Ainsi lorsque celui-ci relèvera le courrier, ce dernier mettra beaucoup trop de temps et la boîte aux lettres deviendra alors inutilisable...

Les solutions au mail bombing sont les suivantes :

- Avoir plusieurs boîtes aux lettres : une principale que vous ne divulguez qu'aux personnes dignes de confiance, et une à laquelle vous tenez moins, utilisée par exemple pour s'inscrire à des services en ligne sur Internet ;
- Installer un logiciel antispam qui interdira la réception de plusieurs messages identiques à un intervalle de temps trop court.

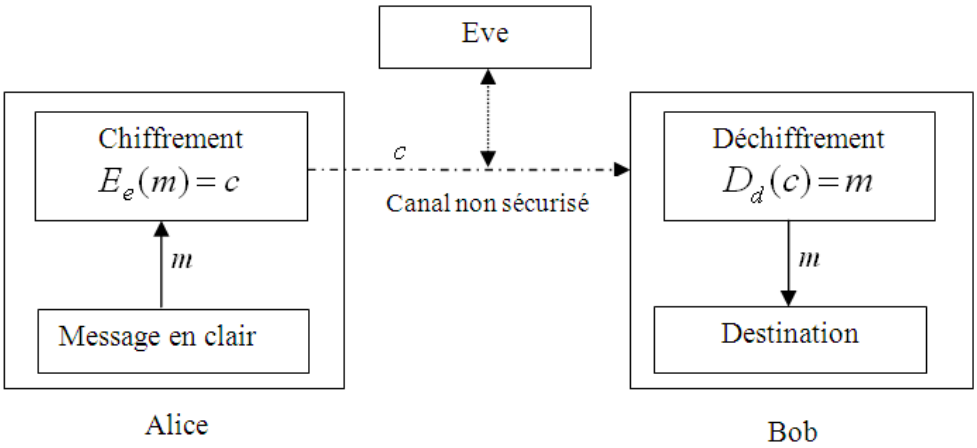
Chapitre 4 Cryptographie

4.1 Principes fondamentaux (Rappel)

4.1.1 Vocabulaire

- **Le chiffrement** est l'opération par laquelle on crypte un message, c'est une opération de codage.
- Chiffrer ou **crypter** une information a pour but de la rendre incompréhensible en l'absence d'un décodeur particulier.
- un **cryptogramme** est un message écrit en langage chiffré (message chiffré).
- La **cryptographie** est la science qui consiste à écrire l'information (voix, son, textes, image fixe ou animée) en la rendant incompréhensible à ceux ne possédant pas les capacités de la déchiffrer.
- La **cryptanalyse** est l'ensemble des moyens qui permettent d'analyser une information chiffrée, afin de la déchiffrer.

Deux participants en communication dans un modèle de chiffrement.



e est la clé de chiffrement.

d est la clé de déchiffrement.

E, D sont les algorithmes du chiffrement et du déchiffrement.

Eve joue le rôle d'un attaquant

4.1.2 Taille de la clé

Une clé codée sur n bits (**taille de la clé**) peut prendre 2^n valeurs. Plus la clé est longue, plus le nombre de clés possibles est important, et plus cela nécessite de la puissance et du temps de calcul (pour un attaquant) pour le trouver.

Une clé de chiffrement/déchiffrement doit avoir **une taille minimale** afin d' éviter qu'elle soit déterminée trop facilement.

Actuellement, 1024 bits ne sont plus jugés suffisamment sécurisées pour les applications modernes pour RSA. Aujourd'hui, on recommande généralement des clés RSA d'au moins **2048** bits pour garantir un bon niveau de sécurité. Des clés de 4096 bits sont parfois utilisées pour une sécurité renforcée.

Le moyen le plus simple pour obtenir une clé est de la procurer directement auprès de l'utilisateur ou à partir du système qui la stocke, plutôt que d'essayer de la deviner par itération.

La taille de la clé utilisée, la puissance de l'algorithme et la capacité à garder les clés secrètes de façon sécurisée, déterminent **la robustesse** d'un système de chiffrement.

L'algorithme n'a pas besoin d'être secret. Il est même recommandé qu'il soit publié afin que la communauté scientifique puisse tester sa résistance aux attaques et trouver les failles avant qu'un attaquant ne les exploite.

Un système de chiffrement est dit **fiable, robuste, sûr ou sécurisé** s'il reste inviolable indépendamment de la puissance de calcul ou du temps dont dispose un attaquant.

Le système est **opérationnellement sécurisé** (computational secure) si sa sécurité dépend d'une série d'opérations réalisables en théorie, mais irréalisable pratiquement (temps de traitement trop long en appliquant les méthodes connues et en utilisant la puissance de calcul disponible).

4.2 Cryptographie symétrique et asymétrique

La **cryptographie traditionnelle** ou classique inclut tous les mécanismes et algorithmes basés sur des fonctions mathématiques ou logiques.

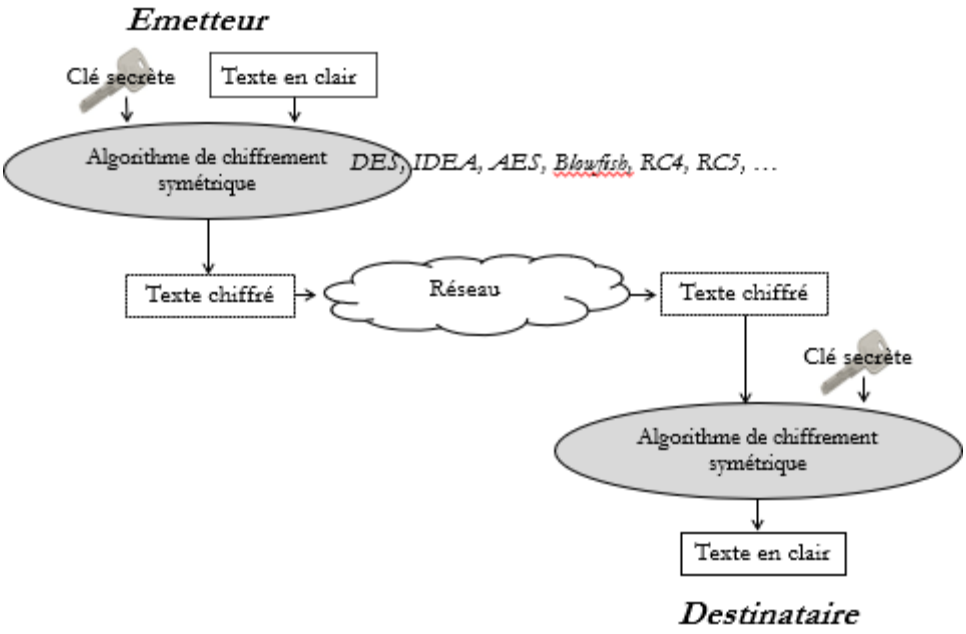
Elle se divise en deux classes de systèmes déchiffrement :

- Le **chiffrement symétrique**
- Les **systèmes de chiffrement asymétrique**

4.2.1 Systèmes de chiffrement symétrique

Pour crypter ou décrypter un texte, il faut détenir **une clé** et **un algorithme de chiffrement**. S'il s'agit de la même clé pour effectuer ces deux opérations, le système de chiffrement est dit **symétrique**.

L'émetteur et le récepteur doivent posséder la même clé secrète pour rendre confidentielles des données et pouvoir les comprendre (chiffrer et déchiffrer).



Un exemple : "chiffrement de César"

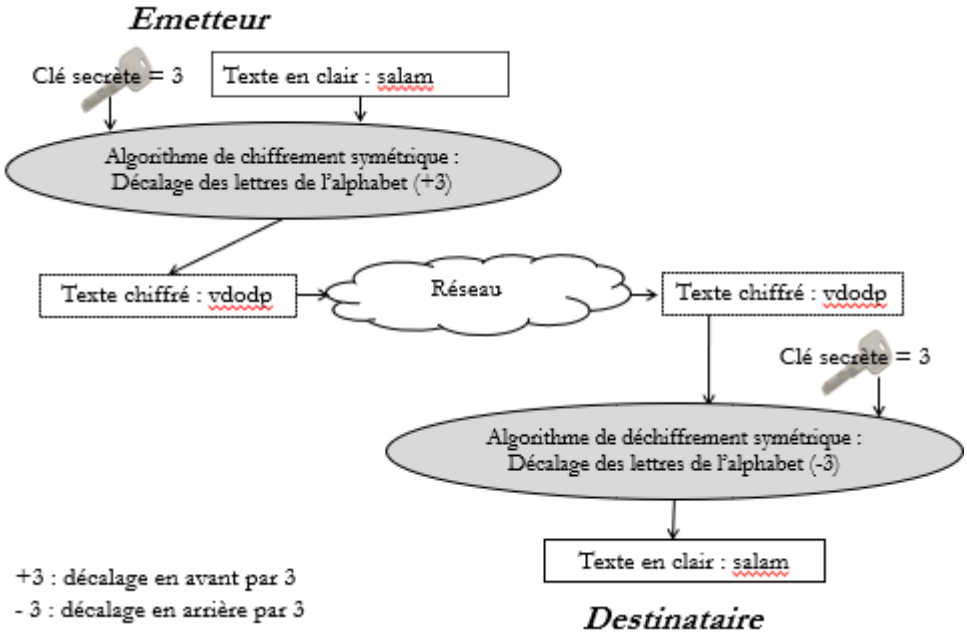
Pour crypter un message, il faut décaler de trois lettres dans l'alphabet chaque lettre du message à transmettre. Pour décrypter un message chiffré, il suffit de décaler chacune des lettres de 3 positions dans le sens inverse de l'alphabet.

Exemple numérique :

- La clé : 3

- Texte en clair : salam

- Texte chiffré : vdodp (décaler en arrière de trois lettres dans l'alphabet)



4.2.2 Principaux algorithmes

- ***DES*** (Data Encryption Standard) a été élaboré par le NIST(National Institute of Standards and Technology) en 1977. Les informations sont chiffrées par blocs de 64 bits avec une clé de 56 bits. Cet algorithme est largement utilisé pour les applications financières. Il est généralement mis en œuvre en un mode dit de chainage de blocs (CBC, Cipher Block Chaining) ou le chiffrement d' un bloc dépend du précédent.
- Les algorithmes ***Triple DES***, ***DESX*** (DES XORed), ***GDES*** (Generalized DES), ***RDES***(Randomized DES) sont déduites de l'algorithme DES, elle exploitent des clés plus longues, rendant ainsi l' algorithme plus puissant. Le triple DES tire son nom du fait que l'on réalise trois niveau de chiffrement ce qui donne une clé effective de chiffrement de 168 bits (56 bits trois trois).
- ***RC2***, ***RC4*** et ***RC5*** sont des algorithmes propriétaires élaborés par Ronald Rivest et diffusé par la société RSA Security Inc. Ces algorithmes utilisent des clés de longueur variable pouvant aller jusqu'à 2048 bits. Ils sont utilisés principalement pour rendre confidentielle des flux applicatifs.
- ***IDEA*** (International Data Encryption Algorithm) élaboré conjointement par des chercheurs de l' école polytechnique fédéral de Zurich et de la société Ascom, utilise une clé de 128 bits pour coder des blocs de données de 64 bits. Il est principalement utilisé par le protocole de messagerie sécurisée PGP (Pretty Good Privacy).
- ***Blowfish*** est un algorithme de chiffrement symétrique implémenté par Bruce Schneierr en 1993.
- ***AES*** (Advanced Encryption Standard) est un algorithme qui a été publié pour la première fois en 1998 par les Belges Vincent Rijmen et Joan Daemen. Il exploite des clés de 128 bits, 192 ou 256 bits sur des blocs de 128 bits. L' AES est considéré rapide, facile à implémenter **et ne requiert que peu de ressource mémoire.** Actuellement, ce système demeure incassable et reste le plus sûr des systèmes de chiffrement symétrique.

4.2.3 Cryptanalyse

- La cryptanalyse des systèmes de chiffrement se base en générale sur la découverte de la clé de chiffrement, sur l'analyse des messages indépendamment de la connaissance des clés.
- En réalité, La majorité des systèmes de chiffrement symétrique sont opérationnellement sécurisés (ils résistent aux attaques de force brute).
- Toutefois, avec le progrès scientifique dans le domaine de l'informatique et de l'électronique, les systèmes jugés actuellement sûrs ne le seront peut être plus dans le futur proche du fait de l'augmentation de la capacité et de la rapidité de traitement mises à disposition de la communauté.
- Le cryptanalyste peut par exemple tester plusieurs clés qui ne diffèrent les unes par rapport aux autres que de quelques bits sur un seul message pour deviner le comportement du système de chiffrement. Ensuite, il va tenter de retrouver les

messages originaux à partir des messages chiffrés sans avoir recours à l'utilisation effective de la clé des utilisateurs.

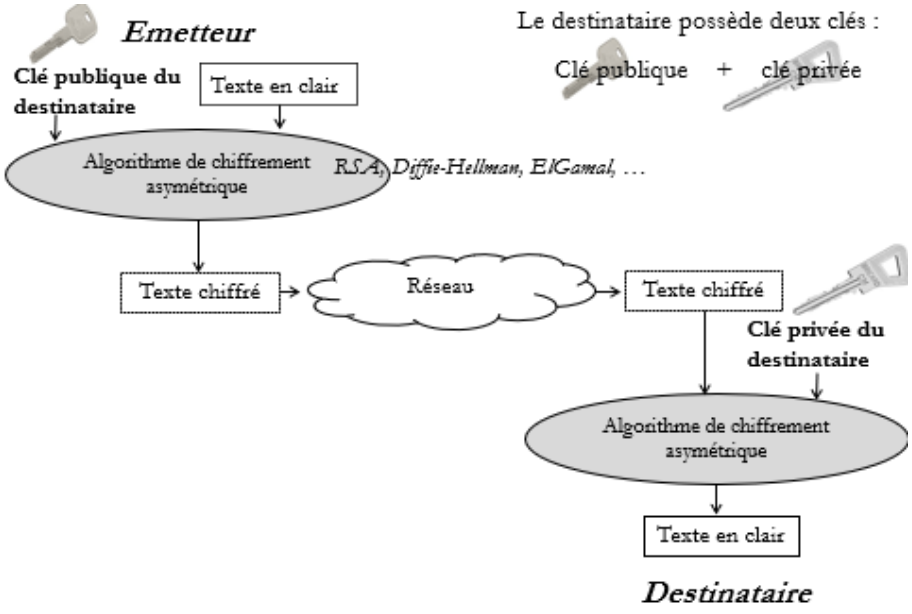
4.2.4 Limites du chiffrement symétrique

- Chaque personne doit posséder autant de clés secrètes qu'elle a d'interlocuteurs. Il faut disposer d'autant de paires différentes de clés qu'il y a de paires de correspondants ! Ce qui devient vite impossible à implémenter et inadapté aux communications multipartenaires et aux services d'Internet.
- Un système de chiffrement symétrique pose donc **le problème de la gestion** et notamment de la distribution des clés secrètes. Cet aspect constitue une faiblesse des systèmes de chiffrement symétrique.
- C'est pour pallier la complexité du problème de la gestion et la distribution des clés des systèmes de chiffrement symétrique qu'un autre type de système de chiffrement, qualifié de **chiffrement asymétrique** ou **chiffrement à clé publique** a été conçu et est actuellement largement utilisé dans le monde d'Internet.

4.3 Système de chiffrement asymétrique

Un système de chiffrement asymétrique est basé sur l'utilisation d'un **couple unique de deux clés** complémentaires, calculées l'une par rapport à l'autre. Ce couple est constitué d'une clé publique (connue par tous) et d'une clé privée (connu par son propriétaire). Seule la clé publique peut être connue de tous, tandis que la clé privée doit être confidentielle et traitée comme un secret.

On doit connaitre la **clé publique** d'un destinataire pour lui envoyer des informations chiffrées. Ce dernier les décryptera à leur réception avec sa **clé privée** qu'il est le seul à connaitre. Le message est confidentiel pour le destinataire dans la mesure où lui seul peut le déchiffrer par sa clé privée.



Un exemple : RSA

Génération des clés par le destinataire :

Le destinataire choisit au hasard deux nombres premiers p et q et calcule $n = pq$. Il choisit au hasard e tel que : $\begin{cases} 1 < e < \phi(n) = (p-1)(q-1) \\ pgcd(e, \phi(n)) = 1 \end{cases}$

$\phi(n)$ le nombre d'entiers, inférieurs à n , premiers avec n . $pgcd(e, \phi(n))$ est le plus grand diviseur commun de $\phi(n)$ et de e .

Le destinataire calcule l'entier d tel que :

$$\begin{cases} 1 < d < \phi(n) \\ ed = 1 \bmod \phi(n) \end{cases}$$

La clé publique du destinataire est le couple (n,e) et sa clé secrète est (n,d).

- Chiffrement :

  L' émetteur récupère la clé publique (n,e) du destinataire et souhaite lui envoyer la version cryptée d'un texte en clair, représenté par la donnée d'un entier m tel que : $0 \leq m < n$. L' émetteur calcule :

$$c = m^e \bmod n$$

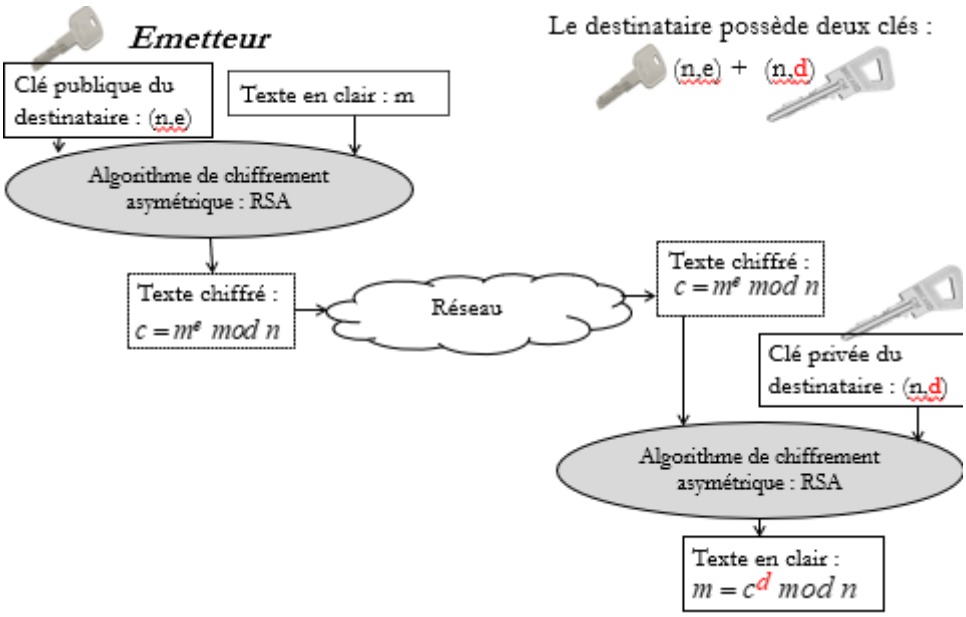
- Déchiffrement :

  Lorsque le destinataire reçoit c , il calcule c^d et récupère ainsi le message m puisque :

$$m = c^d \bmod n$$

- Notes :

  1) Ce qu'est en rouge sont des nombres privée du destinataire.



Le challenge RSA :

Notes : Pour avoir une sécurité optimale il ne faut plus utiliser des clés RSA inférieures à 2048 bits. Selon les chercheurs, RSA-1024 devrait résister pendant encore qlq années.

Un autre exemple : l'algorithme ElGamal

Si RSA est un des algorithmes à clé publique les plus populaires, il en existe quelques autres. L'un d'entre eux, **l'algorithme ElGamal**, a été développé par Taher ElGamal en 1984. Il n'est pas breveté et peut être utilisé librement.

Ce cryptosystème repose sur la difficulté de la résolution du logarithme discret.

(si $y = g^x \bmod p$, on dit que x est le logarithme discret de y de base g modulo p)

Il présente l'avantage de faire appel à deux processus aléatoires, mais présente l'inconvénient de générer des messages chiffrés particulièrement longs.

Notes :

La mise en œuvre du chiffrement asymétrique permet de vérifier l' origine d' un message et d' authentifier un émetteur (utilisation de signature et certificat).

Autres algorithmes de crypto asymétrique :

Certains algorithmes basés sur les équations de calcul de circonférences des ellipses sont à l'origine de la cryptographie à courbe elliptique (ECC, Elliptic Curve Cryptography), qui pourrait remplacer les algorithmes actuels.

Note : Même en l'absence de la diffusion d'une méthode prouvant qu'un algorithme a été cassé, cela ne veut pas dire que la méthode n'existe pas ou que l'algorithme n' a pas été cassé. Aucune preuve mathématique ne permet d'affirmer que ce n'est pas possible.

4.4 Clés secrètes

La sécurité du processus des chiffrements repose en grande partie sur la sécurité et la **confidentialité des clés** utilisées, sur la robustesse des algorithmes et sur la sécurité des plates-formes matérielles et logicielles qui les supportent.

La durée de vie d'une clé de chiffrement (et de déchiffrement) dépend de son utilisation. Il est conseillé de changer la clé périodiquement, tout en évitant les modification trop fréquentes qui rendent difficile la gestion des clés. En revanche, pour toutes les applications ouvertes au réseau, il est hautement souhaitable d'utiliser une clé à usage unique, particulière à chaque session de travail.

Le système de gestion de clés basé sur l'usage d'une carte à puce (et d'un lecteur de carte) autorise l'usage d'une clé unique à chaque session de travail.

Les fonctions d'un système de gestion de clés sont celles qui permettent de réaliser les services de:

- Génération d'une clé en fonction des besoins et des systèmes de chiffrement;
- Distribution des clés aux entités (vérification, authentification des entités, etc.);

- Stockage des clés de manière sécurisée (chiffrement des clés , sécurité du serveur, archivage fiable afin d'assurer la confidentialité et l' intégrité des clés);
- Surveillance(monitoring), d' enregistrement, d'audit , de traçage, de sécurité, de test de bon fonctionnement, d'alarme de contrôle d' accès aux clés, etc.;
- Destruction des clés inutiles (destruction physique, etc.);

Dans un système d'information, plusieurs clés de chiffrement sont généralement utilisées. Il peut alors exister une certaine **hiérarchie des clés** (notion de clé maitresse, physiquement protégée, et de clés filles chiffrées à partir de celle-ci).

Chapitre 5 Infrastructure de gestion de clés (PKI)

5.1 Définition

(PKI, pour *Public Key Infrastructure*) est un système qui permet de gérer, distribuer et vérifier les clés de chiffrement et les certificats numériques utilisés pour la sécurité des communications dans un réseau informatique.

5.2 Composants clés de la PKI

1. **Certificats numériques** : Documents électroniques contenant une clé publique et l'identité de l'entité (utilisateur, serveur). Ils sont émis pour authentifier l'entité et garantir qu'elle possède bien la clé publique associée.

2. **Paire de clés (clé publique et clé privée)** : La PKI utilise un chiffrement asymétrique basé sur deux clés différentes. La clé publique est partagée publiquement, tandis que la clé privée reste secrète. Les données chiffrées avec la clé publique ne peuvent être déchiffrées qu'avec la clé privée correspondante.

3. **Autorité de certification (CA)** : Entité de confiance qui émet, distribue et gère les certificats numériques. Elle vérifie l'identité des entités avant de délivrer un certificat numérique.

4. **Autorité d'enregistrement (RA)** : Sous-ensemble de la CA, qui aide à vérifier l'identité des entités qui demandent un certificat.

5. **Autorité de révocation des certificats** : Entité qui gère les certificats révoqués, soit en les plaçant dans une liste de révocation de certificats (CRL), soit en utilisant un service de vérification en temps réel (OCSP: Online Certificate Status Protocol).

5.3 Fonctionnement de la PKI

1. **Demande de certificat** : Lorsqu'une entité (comme un utilisateur ou un serveur) veut un certificat, elle génère une paire de clés et soumet une requête à la CA, qui vérifie son identité.

2. **Émission de certificat** : Une fois l'identité validée, la CA délivre un certificat numérique contenant la clé publique de l'entité et l'information vérifiée (comme son nom, son adresse, etc.). Ce certificat est signé par la CA, ce qui garantit sa validité.

3. **Vérification** : Les autres entités peuvent vérifier l'authenticité d'un certificat en s'assurant que la signature numérique de la CA est valide.

4. **Utilisation de la clé** : La clé publique du certificat est utilisée pour chiffrer les communications, tandis que la clé privée de l'entité permet de signer les documents et les transactions.

5. **Révocation** : Si la clé privée d'une entité est compromise, la CA révoque le certificat, ce qui est signalé sur une liste de révocation de certificats (CRL) ou via OCSP pour des vérifications en temps réel.

5.4 Raisons de révocation d'un certificat

1. **Compromission de la clé privée** : Si la clé privée associée au certificat est perdue ou volée, l'entité ne peut plus garantir la sécurité de ses communications. La révocation protège ainsi les utilisateurs des attaques.
2. **Changement d'identité ou de statut de l'entité** : Si l'entité, comme une entreprise ou un employé, change d'identité (par exemple, l'employé quitte l'entreprise), son certificat peut être révoqué pour éviter des utilisations frauduleuses.
3. **Non-respect des conditions d'utilisation** : Si l'entité a enfreint les règles de sécurité ou les politiques d'utilisation du certificat, la CA peut révoquer son certificat.
4. **Erreur dans le certificat** : Si une information dans le certificat est incorrecte, la CA peut révoquer le certificat pour émettre une version corrigée.

5.4.1 Utilisations de la PKI

La PKI est employée dans divers contextes pour assurer la sécurité des communications :

- **SSL/TLS pour les sites web** (certificats SSL),
- **Authentification des utilisateurs et des appareils** (pour les réseaux privés virtuels VPN, les systèmes d'authentification forte),
- **Chiffrement et signature des e-mails** (S/MIME),
- **Signatures numériques pour les documents** (signatures juridiquement contraignantes)

5.4.2 Infrastructure de gestion de clés

Les principales fonctions d'une infrastructure PKI sont:

- Génération d'un couple de clés (privée et publique) et l' attribuer à une entité;
- Gestion des certificats : émission, signature, validation, etc.;
- Sauvegarde : archivage des clés, procédures de recouvrement en cas de pertes;
- Diffusion des clés publiques aux entités qui la demandaient;
- Certification des clés publiques (signer les certificats).

5.4.3 Certificat numérique

Un certificat numérique c'est comme **une carte d'identité** d'une ressource informatique.

Parmi les informations notées sur un certificat d'une ressource :

- L'identification de son propriétaire ;

- La clé publique qui lui est attribuée ;

- L'identification de l'organisme qui l'a délivrée.

Selon **le degré de vérification**, plusieurs types de certificats peuvent être émis. Si processus d'authentification est rigoureux plus on a la confiance dans le certificat.

La norme **X.509** présente un cadre architectural pour l'élaboration d'un service d'authentification basé sur l'usage de certificats.

La norme du certificat **X.509 est largement utilisée.** Elle est à la base de nombreuses solution du marché comme par exemple S/MIME (Secure/Multipurpose Internet Mail Extensions), IPsec (Internet Protocol Security), SSL(Secure Socket Layers), SET(Secure Electronic Transaction).

La figure suivante illustre les principaux paramètres d'un certificat numérique selon la norme X.509 "Directory Authentification Framework".

5.4.4 Principaux paramètres d' un certificat numérique selon la norme X.509

- Principaux paramètres d' un certificat numérique selon la norme X.509

Version du certificat
Numéro de série
Algorithme utilisé pour signer le certificat
Nom de l' organisme qui a généré le certificat Le couple (*numéro de série , nom de l' organisme*) doit être unique
Période de validité
Nom du propriétaire du certificat
Clé publique du propriétaire
Informations additionnelles concernant le propriétaire ou les mécanismes de chiffrement
Signature du certificat *Algorithme et paramètres utilisés pour la signature*

- Note : Pour ouvrir Gestionnaire de certificats de Windows, cliquez sur le bouton Démarrer, tapez *certmgr.msc* dans la zone de recherche, puis appuyez sur ENTRÉE.

Pour valider le certificat reçu :

- Le client doit utiliser la clé publique de l'organisme qui a créé le certificat relatif à l'algorithme utilisé pour signer le certificat (champ 3).

- Le client doit décrypter la signature numérique contenue dans le dernier champ "Signature du certificat".

Procédure d'authentification du certificat :

- Le client calcule la valeur du condensé (hash **des données signées**) et compare la valeur trouvée avec celle obtenue après le déchiffrement de la signature.
- Si les deux valeurs correspondent, cela signifie que le certificat a été émis par une autorité de certification de confiance et n'a pas été modifié.

- Le client doit s'assurer enfin que la période de validité du certificat est correcte.

NB : **Les données signées** (TBS Certificate - To Be Signed Certificate) incluent toutes les informations du certificat sauf la signature elle-même.

Un organisme de certification a pour fonction principale de produire des certificats établissant la valeur de la clé publique, attribuée à une entité (par une PKI). Les étapes à suivre par un client :

1) **Un client émet une demande** de certification auprès d'une autorité de certification (par service web).

2) **Des preuves de l'identité du client** peuvent être suggérées par le serveur d'enregistrement.

3) Une fois les données du client sont validées, **le serveur de certification crée les clés de chiffrement et un certificat numérique au nom du client. Le certificat est signé par la clé privée de cet organisme et ensuite envoyé au client.**

4) Le client utilise la clé publique de l'autorité pour **s'assurer que le certificat est bien généré par l'autorité** en question.

5.4.5 Limites

Disposer d'une seule autorité mondiale de certification n'est pas souhaitable (du fait de l' importance de l' infrastructure à mettre en place)..

Diverses autorités de certification existent. **Il est nécessaire d'implémenter des mécanismes assurant l'interopérabilités des autorités de certification**.

La multiplicité des autorités de certification crée le problème de leur reconnaissance mutuelle, de la comptabilité des certificats et du champ de leur validité en vue de délivrer un service universel et reconnu par tous.

Les limites inhérentes aux infrastructures de gestion de clés résident dans:

- la complexité, le coût de déploiement et de la gestion d'une infrastructure;

- le haut niveau de sécurité nécessaire à la réalisation des services;

- la validité, la durée de vie, les résiliations des certificats.

5.4.6 Exemple de transaction sécurisée par l'intermédiaire d'une PKI

Une entreprise et ses clients désirant s'échanger des données de manière confidentielle peuvent faire appel aux services proposés par PKI.

1) Tout d'abord **l'entreprise doit s'enregistrer** auprès d'une autorité d'enregistrement qui lui attribue un certificat numérique (étape a).

2) **La PKI publie le certificat** et peut le délivrer à des entités qui veulent communiquer avec l'entreprise. Le certificat contient des informations sur :

- l'entreprise,

- la PKI qui l'a délivré,

- l'algorithme de chiffrement,

- la fonction de hachage,

- la clé publique de l'entreprise.

Note : **Le certificat est signé avec la clé privée de la PKI**. La clé privée de l'entreprise lui est envoyée par la PKI par voie sécurisée (en mains propres ou par la poste par exemple).

Afin d'établir une **transaction internet sécurisée** entre le client et l'entreprise:

1) **le client doit se connecter sur le site web de l'entreprise** (étape b) et obtenir le nom de la PKI ainsi que le numéro de série du certificat de l'entreprise.

2) Ensuite, **le navigateur du client se connecte sur le site de la PKI et télécharge le certificat de l'entreprise** (étape c). Il s'assure de l'authenticité du certificat en vérifiant la signature du certificat avec la clé publique de la PKI. Il vérifie l'intégrité des donnés en appliquant l'algorithme de hachage. Il extrait du certificat la clé publique de l'entreprise.

3) **Le client crée une clé de session** (clé privé), selon les navigateurs, puis la transmis à l'entreprise en la chiffrant avec sa la clé publique (étape d).

4) En recevant le message chiffré, l'entreprise le déchiffre avec sa clé privée, obtient ainsi sa clé de session qu'elle utilisera pour chiffrer/déchiffrer les données échangées avec ce client. La clé de session est utilisée seulement durant une session de travail bien déterminée (étape e).

5.4.7 Cas particulier d'autorité de certification privée

- Une entreprise peut créer des certificats pour son propre compte et **devenir sa propre autorité de certification**.
- **La validité des certificats se limite aux frontières de l'entreprise** et ces certificats ne peuvent servir pour se connecter à des serveurs internet externes sauf si le certificat est signé par une autre autorité de certification reconnue.
- Note : Il faut que l'entreprise soit capable de bien sécuriser la machine dédiée à l'attribution et à la gestion des certificats. Ainsi la gestion d'un service de certification peut s'avérer complexe.
- Avantage : Quand on devient sa propre autorité de certification **on a le contrôle complet de la politique d'émission et de révocation des certificats**.

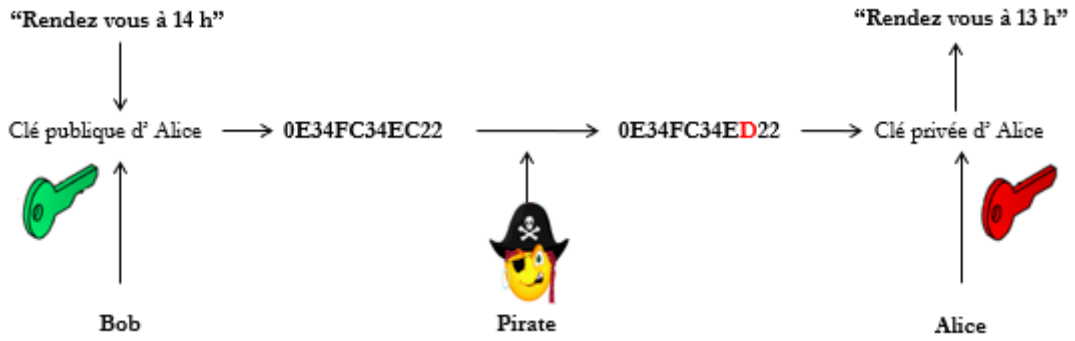
5.5 Empreinte d'un message

- La cryptologie à clé publique

- Permet de garantir la confidentialité des messages échangées

- **Ne garantit pas l'intégrité du message**

Définition: Garantir l'intégrité d'un message consiste à pouvoir détecter toute modification malicieuse du message entre le moment de son émission et l'instant où il est reçu.

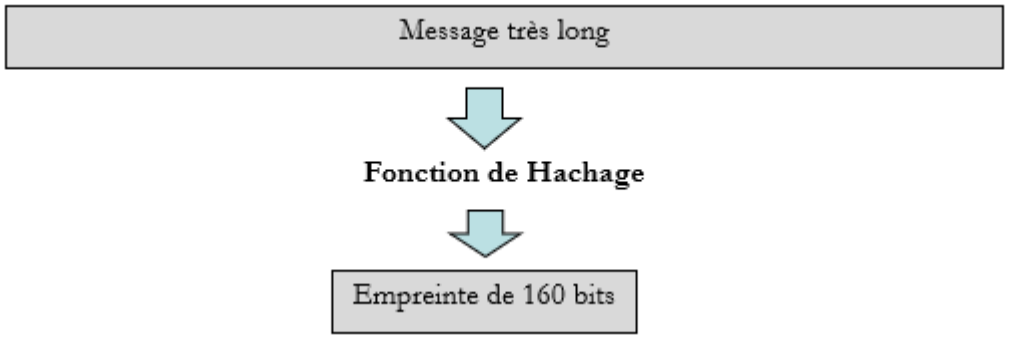


Une empreinte numérique est un résumé d'un message, aussi appelé condensé. Elle est de taille fixe (souvent entre 128 à 160 bits).

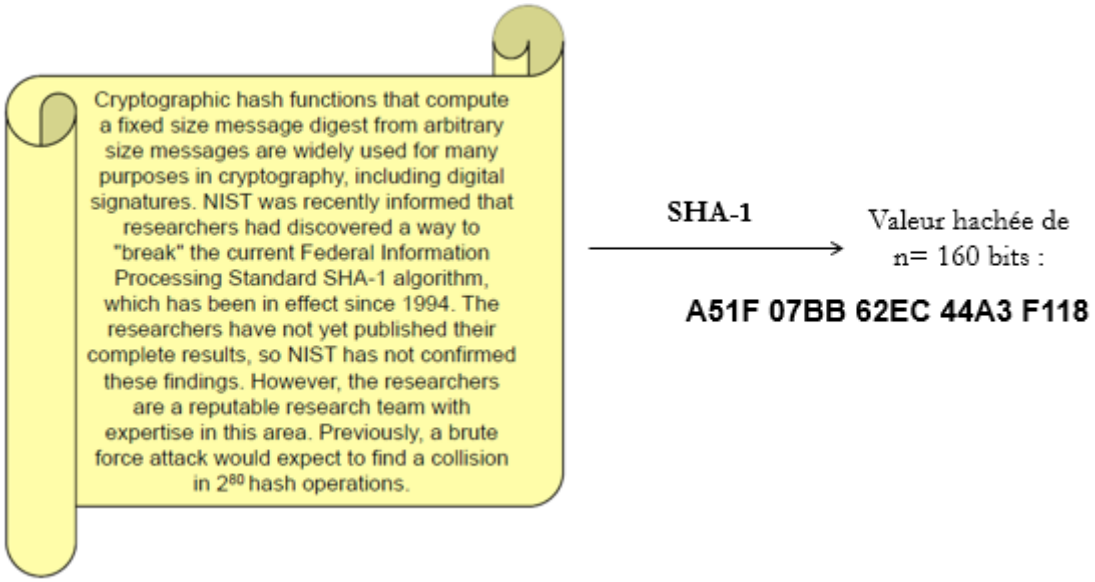
Deux documents légèrement différents ont des empreintes très différentes .

Il est très difficile de construire un document qui ait la même empreinte qu'un autre document (Propriété de sens unique).

Algorithmes utilisés : MD5, SHA-1, etc. Ces algorithmes sont appelés fonction de hachage.



- Exemple d'empreinte d'un message :



L'empreinte est utilisée pour vérifier l'intégrité d'un message. Si le message et son empreinte ne correspondent plus, il y a surement eu une manipulation du message.

Exemple : Soit une vraie clé publique RSA téléchargée d'un annuaire :

"30818902818100a32d946ea519646f84109e62548bfa7050c5ab378
fbfd4ac099815c1edb2e4530f1de18033ea79c4f371f0784f24828668
4220b240a9fc2fc17879d28bbe916518292db70b62c5e0aaea56fa32a
534ec5162706b2b63d79d222167c549e0546a0194384c685e56619169
0ff7baa1f867d5983c7b78b573dcee4b51a29f72c0070203010001"

Allez vous passer du temps à téléphoner à votre correspondant pour vérifier bit à bit que cette valeur est exacte? Evidemment non! Le plus simple consiste alors pour le correspondant à publier dans un annuaire l'empreinte numérique de sa clé:

Empreinte MD5:

A031:51E1:D1CD:DE6D:3C06:5185:C6FA:F80A

Empreinte SHA-1:

FE50:98DD:C8EC:2E6B:EE74:77CF:DDAC:0196:FD3B:D8DD

De votre côté, vous téléchargez cette clé, puis recalculez son empreinte numérique à l'aide soit de MD5, soit de SHA-1; vous effectuez ensuite la comparaison. En quelques secondes, vous saurez si vous avez téléchargé la bonne clé.

De même, vous téléchargez un logiciel. Comment savoir si vous rapatriez le bon logiciel, ou une version piratée ? Vous n'allez certainement pas inspecter le code avant de l'utiliser. Un moyen simple consiste encore à s'appuyer sur les empreintes numériques. Aujourd'hui, tous les éditeurs – ou presque ! – publient sur leurs sites au minimum les condensés MD5 et SHA-1 de leurs logiciels ; à vous de faire le nécessaire pour vérifier si la version chargée sur votre poste est bien celle de l'éditeur.

- Note : pour utiliser les algorithmes MD5 ou SHA-1 utilisez les logiciels suivants : md5sum.exe et sha1sum.exe.

5.6 Signature numérique

But des signatures manuscrites :

- prouver l'identité de leur auteur **et/ou**
- l'accord du signataire avec le contenu du document

La signature électronique dépend du signataire et du document!

Propriétés d'une signature électronique :

- Authentique : convaincre le destinataire que le signataire a délibérément signé un document
- Infalsifiable
- Non réutilisable : attachée à un document donné
- Inaltérable : toute modification du document est détectable
- Non reniable : le signataire ne peut répudier le document

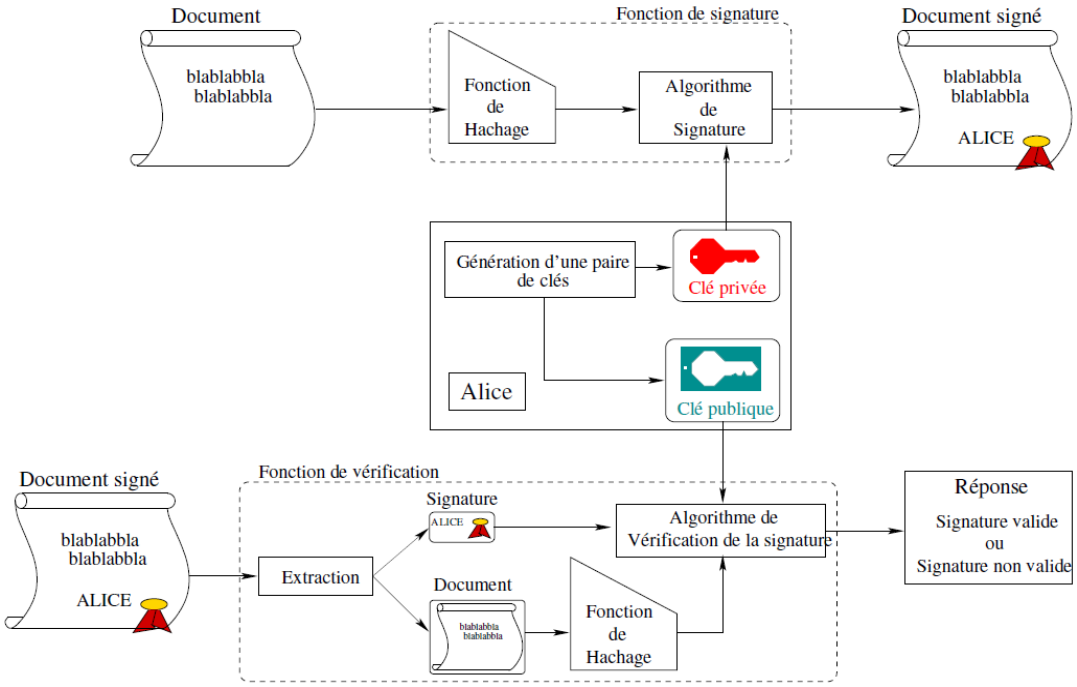
La signature assure les services suivants :

Intégrité + Authentification + Non-répudiation

5.7 Signature et hachage

Réalisation pratique : Cryptosystèmes à clé publique + fonction de hachage

On préfère en effet signer le hachage d'un document ! Taille fixe suffisamment petite pour être utilisée efficacement par un cryptosystème à clé publique.



5.8 Certificat/ signature numérique

Le certificat électronique est un document numérique permettant de valider le lien entre une signature électronique et son signataire.

La signature électronique est le procédé d'identification de l'auteur d'un document électronique. Elle est la garantie de son intégrité (preuve que le document n'a pas subi d'altération entre l'instant où il a été signé par son auteur et celle où il a été consulté).

La signature électronique possède la même valeur juridique qu'une signature manuscrite.

Chapitre 6 IDS : Systèmes de détection d'intrusion

6.1 Introduction

Détection d'attaques : afin de détecter les attaques que peut subir un système, il est nécessaire de disposer d'un logiciel spécialisé dont le rôle sera de surveiller les données qui transitent sur ce système et qui serait capable de réagir si des données semblent suspectes.

C'est le rôle des systèmes de détection d'intrusion : les IDS.

Définition : Un système de détection d'intrusion (ou IDS : Intrusion Detection System) est un mécanisme destiné à repérer des activités anormales ou suspectes sur la cible analysée (un réseau ou un hôte). Il permet ainsi d'avoir une action de prévention sur les risques d'intrusion.

Autre définition : ensemble de composants logiciels et matériels dont la fonction principale est de détecter et d'analyser toute tentative d'intrusion (volontaire ou non).

Deux notions fondamentales :

- Faux positifs : une alerte provenant d'un IDS mais qui ne correspond pas à une attaque réelle.
- Faux négatifs : une intrusion réelle qui n'a pas été détectée.

6.2 Les différents types d'IDS

A cause de la diversité des attaques que mettent en œuvre les pirates, la détection d'intrusion doit se faire à plusieurs niveaux.

Il existe donc différents types d'IDS :

- Les systèmes de détection d'intrusions "réseaux" (NIDS)
- Les systèmes de détection d'intrusions de type hôte (HIDS)
- Les systèmes de détection d'intrusions hybrides
- Les systèmes de prévention d'intrusions (IPS)
- Les systèmes de prévention d'intrusions "noyau" (KIDS/KIPS)
- Les pare-feux

6.2.1 Les systèmes de détection d'intrusions "réseaux" (NIDS)

Objectif : analyser de manière passive les flux en transit sur le réseau et détecter les intrusions en temps réel.

Un NIDS écoute donc tout le trafic réseau, puis l'analyse et génère des alertes si des paquets semblent dangereux.

Les NIDS sont les IDS plus intéressants et les plus utiles du fait de l'omniprésence des réseaux dans notre vie quotidienne.

6.2.2 Les systèmes de détection d'intrusions de type hôte (HIDS)

Un HIDS se base sur une unique machine, n'analysant cette fois plus le trafic réseau mais l'activité se passant sur cette machine. ils surveillent les processus, les pilotes, les .dll, etc.

Il analyse en temps réel les flux relatifs à une machine ainsi que les journaux.

Un HIDS a besoin d'un système sain pour vérifier l'intégrité des donnés. Si le système a été compromis par un pirate, le HIDS ne sera plus efficace.

Il existe des KIDS (Kernel Intrusion Detection System) et KIPS (Kernel Intrusion Prevention System) qui sont fortement liés au noyau, mais ils sont moins utilisés.

6.2.3 Les systèmes de détection d'intrusions "hybrides"

Généralement utilisés dans un environnement décentralisé, ils permettent de réunir les informations de diverses sondes placées sur le réseau.

Leur appellation « hybride » provient du fait qu'ils sont capables de réunir aussi bien des informations provenant d'un système HIDS qu'un NIDS.

L'exemple le plus connu dans le monde Open-Source est Prelude. Ce framework permet de stocker dans une base de données des alertes provenant de différents systèmes relativement variés.

Utilisant Snort comme NIDS, et d'autres logiciels tels que Samhain en tant que HIDS, il permet de combiner des outils puissants tous ensemble pour permettre une visualisation centralisée des attaques.

6.2.4 Les systèmes de prévention d'intrusions (IPS)

Définition : ensemble de composants logiciels et matériels dont la fonction principale est d'empêcher toute activité suspecte détectée au sein d'un système.

Les IPS sont des outils aux fonctions « actives », qui en plus de détecter une intrusion, tentent de la bloquer. Les IPS ne sont pas la solution parfaite.

Plusieurs stratégies de prévention d'intrusions existent :

- **host-based memory and process protection :** surveille l'exécution des processus et les tue s'ils ont l'air dangereux (buffer overflow). Cette technologie est utilisée dans les KIPS (Kernel Intrusion Prevention System).

- **session interception / session sniping :** termine une session TCP avec la commande TCP Reset : « RST ». Ceci est utilisé dans les NIPS.
- **gateway intrusion detection :** si un système NIPS est placé en tant que routeur, il bloque le trafic ; sinon il envoie des messages à d'autres routeurs pour modifier leur liste d'accès.

6.2.4.1 Les inconvénients des IPS (1/2)

Un IPS possède de nombreux inconvénients :

- Le premier est qu'il bloque toute activité qui lui semble suspecte. Or, il est impossible d'assurer une fiabilité à 100% dans l'identification des attaques. Un IPS peut donc bloquer du trafic inoffensif !
  Exemple : un IPS peut détecter une tentative de déni de service alors qu'il s'agit d'une période chargée en trafic.
  Les faux positifs sont donc très dangereux pour les IPS.
- Le deuxième inconvénient est qu'un pirate peut utiliser sa fonctionnalité de blocage pour mettre hors service un système. Prenons l'exemple d'un individu mal intentionné qui attaque un système protégé par un IPS, tout en spoofant son adresse IP. Si l'adresse IP spoofée est celle d'un nœud important du réseau, les conséquences seront catastrophiques. Pour pallier ce problème, de nombreux IPS disposent des « white lists », c-à-d des listes d'adresses réseaux qu'il ne faut en aucun cas bloquer.
- Et enfin, le troisième inconvénient : un IPS est peu discret. En effet, à chaque blocage d'attaque, il montre sa présence. Cela peut paraître anodin, mais si un pirate remarque la présence d'un IPS, il tentera de trouver une faille dans celui-ci afin de réintégrer son attaque... mais cette fois en passant inaperçu.

Voilà pourquoi les IDS passifs sont souvent préférés aux IPS.

6.2.5 Les IPS "noyau" (KIDS/KIPS)

Dans le cadre du HIDS, l'utilisation d'un détecteur d'intrusions au niveau noyau peut s'avérer parfois nécessaire pour sécuriser une station.

Exemple d'un serveur web : il serait dangereux qu'un accès en lecture/écriture dans d'autres répertoires que celui consultable via http, soit autorisé. Cela pourrait nuire à l'intégrité du système.

Grâce à un KIPS, tout accès suspect peut être bloqué directement par le noyau, empêchant ainsi toute modification dangereuse pour le système.

Le KIPS peut reconnaître des motifs caractéristiques du débordement de mémoire, et peut ainsi interdire l'exécution du code.

Le KIPS peut également interdire l'OS d'exécuter un appel système qui ouvrirait un shell de commandes. Puisqu'un KIPS analyse les appels systèmes, il ralentit l'exécution. C'est pourquoi ce sont des solutions rarement utilisées sur des serveurs souvent sollicités.

Exemple de KIPS : SecureIIS, qui est une surcouche du serveur IIS de Microsoft.

6.3 Les méthodes de détections

Comprendre les systèmes de détection d'intrusions nécessite de se poser les questions :

- Comment une intrusion est-elle détectée par un tel système ?
- Quel critère différencie un flux contenant une attaque d'un flux normal ?

A partir de ces questions, nous pouvons étudier le fonctionnement interne d'un IDS.

Deux techniques principales sont mises en place dans la détection d'attaques :

- La première consiste à détecter des signatures d'attaques connues dans les paquets circulant sur le réseau.
- La seconde, consiste quant à elle, à détecter une activité suspecte dans le comportement de l'utilisateur.

⇒ Ces deux techniques, aussi différentes soient-elles, peuvent être combinées au sein d'un même système afin d'accroître la sécurité.

6.3.1 L'approche par scénario

Cette technique s'appuie sur la connaissance des techniques utilisées par les attaquants pour déduire des scénarios typiques.

Elle ne tient pas compte des actions passées de l'utilisateur et utilise des signatures d'attaques : Ensemble de caractéristiques permettant d'identifier une activité intrusive : une chaîne alphanumérique, une taille de paquet inhabituelle, une trame formatée de manière suspecte, ...

6.3.1.1 Recherche de motifs (pattern matching)

La méthode la plus connue et la plus à facile à comprendre.

Elle se base sur la recherche de motifs (chaînes de caractères ou suite d'octets) au sein du flux de données.

L'IDS comporte une base de signatures où chaque signature contient les protocoles et ports utilisés par l'attaque ainsi que le motif qui permettra de reconnaître les paquets suspects.

Le principal inconvénient de cette méthode est que seules les attaques reconnues par les signatures seront détectées. Il est donc nécessaire de mettre à jour régulièrement la base de signatures.

Un autre inconvénient est que les motifs sont en général fixes.

- Or, une attaque n'est pas toujours identique à 100%.
- Le moindre octet différent par rapport à la signature provoquera la non détection de l'attaque.

Pour les IDS utilisant cette méthode, il est nécessaire d'adapter la base de signatures en fonction du système à protéger.

6.3.1.2 Recherche de motifs dynamiques

Le principe de cette méthode est le même que précédemment mais les signatures des attaques évoluent dynamiquement.

L'IDS est de ce fait doté de fonctionnalités d'adaptation et d'apprentissage.

6.3.1.3 Analyse de protocoles

Cette méthode se base sur une vérification de la conformité des flux, ainsi que sur l'observation des champs et paramètres suspects dans les paquets.

L'analyse protocolaire est souvent implémentée par un ensemble de préprocesseurs, où chaque préprocesseur est chargé d'analyser un protocole particulier (FTP, HTTP, ICMP, ...).

Du fait de la présence de tous ces préprocesseurs, les performances dans un tel système s'en voient fortement dégradées.

L'intérêt fort de l'analyse protocolaire est qu'elle permet de détecter des attaques inconnues, contrairement au pattern matching qui doit connaître l'attaque pour pouvoir la détecter.

6.3.1.4 Analyse heuristique et détection d'anomalies

Le but de cette méthode est, par une analyse intelligente, de détecter une activité suspecte ou toute autre anomalie.

Par exemple : une analyse heuristique permet de générer une alarme quand le nombre de sessions à destination d'un port donné dépasse un seuil dans un intervalle de temps prédéfini.

6.3.2 L'approche comportementale

Cette technique consiste à détecter une intrusion en fonction du comportement passé de l'utilisateur.

Pour cela, il faut préalablement dresser un profil utilisateur à partir de ses habitudes et déclencher une alerte lorsque des événements hors profil se produisent.

Cette technique peut être appliquée non seulement à des utilisateurs mais aussi à des applications et services.

Plusieurs métriques sont possibles : la charge CPU, le volume de données échangées, le temps de connexion sur des ressources, la répartition statistique des protocoles et applications utilisés, les heures de connexion, ...

6.3.3 Inconvénients de l'approche comportementale

- peu fiable : tout changement dans les habitudes de l'utilisateur provoque une alerte.
- nécessite une période de non fonctionnement pour mettre en œuvre les mécanismes d'auto-apprentissage :

- si un pirate attaque pendant ce moment, ses actions seront assimilées à un profil utilisateur, et donc passeront inaperçues lorsque le système de détection sera complètement mis en place.

- l'établissement du profil doit être souple afin qu'il n'y ait pas trop de fausses alertes :

- le pirate peut discrètement intervenir pour modifier le profil de l'utilisateur afin d'obtenir après plusieurs jours ou semaines, un profil qui lui permettra de mettre en place son attaque sans qu'elle ne soit détectée.

6.3.4 Différentes méthodes dans l'approche comportementale

- Approche probabiliste :

Des probabilités sont établies permettant de représenter une utilisation courante d'une application ou d'un protocole. Toute activité ne respectant pas le modèle probabiliste provoquera la génération d'une alerte.

Exemple : Avec le protocole HTTP, il y a une probabilité de 0.9 qu'une commande GET soit faite après une connexion sur le port.

- Approche statistique :

Le but est de quantifier les paramètres liés à l'utilisateur : taux d'occupation de la mémoire, utilisation des processeurs, valeur de la charge réseau, nombre d'accès par jour, vitesse de frappe au clavier, sites les plus visités, ...

Elle n'est actuellement présente que dans le domaine de la recherche, où les chercheurs utilisent des réseaux neuronaux et la fouille de données pour tenter d'avoir des résultats convaincants.

6.4 Les méthodes répandues

Les IDS mélangent généralement les différentes méthodes de détection d'intrusions.

Pattern Matching	→algorithmes de recherche de motifs →algorithmes de comptage →algorithmes génétiques
Analyse Protocolaire	→conformité aux RFC
Détection d'anomalies	→méthodes heuristiques
Analyse statistique	→modèles statistiques
Analyse probabiliste	→réseaux bayésiens
Autres méthodes	→réseaux de neurones →systèmes experts →fouille de données →immunologie →graphes

6.5 Principes généraux et déploiement

Un NIDS n'est pas suffisant pour assurer la sécurité.

Il faut aussi effectuer les actions habituelles :

- les systèmes et applications doivent être mises à jour régulièrement (mises à jour de sécurité).

- les systèmes utilisant internet doivent être dans un réseau isolé.

- chaque utilisateur doit être averti de l'importance de la sécurité de ses mots de passe.

- les services qui ne sont pas utilisés doivent être désactivés.

Le déploiement d'un IDS doit tenir compte du système d'exploitation et les règles doivent être correctement configurées par rapport à celui-ci.

L'emplacement des sondes est très important : i.e. l'endroit où l'on capture le trafic réseau.

Il faut penser à sécuriser les sondes et les logs d'alerte.

Il faut configurer correctement l'IDS pour qu'il n'inonde pas les rapport d'alertes avec des faux positifs.

- Ils peuvent rendre les rapports d'alertes long à analyser.
- Les administrateurs passeront beaucoup de temps à distinguer les faux positifs des véritables intrusions.

Il faut aussi veiller à ce que l'IDS ne génère pas de faux négatifs.

Les débits actuels des réseaux augmentent de plus en plus et donc les IDS ont de plus en plus de paquets à traiter et à analyser.

6.6 Fonctionnement d'un IDS

6.6.1 Les étapes de fonctionnement

- Capture de la trame par l'interface en mode promiscuité (promiscous mode 1).

- Analyse de la trame et filtrage éventuel en bas niveau.
- Détection de la présence de fragments ou non et passage éventuel à un moteur de reconstruction.
- Transfert de la trame vers le système d'exploitation.
- Filtrage éventuel.
- Applications de divers préprocesseurs en fonction du type de requête afin de contrer des techniques d'évasion d'attaques
- Passage vers le moteur d'analyse (protocole, pattern matching, statistique, ...).
- Répartition de charges et amélioration des performances

  ⇒ séparer les flux et mettre en place plusieurs sondes.
- L'utilisation de plusieurs sondes nécessite la corrélation des informations par le biais de plusieurs actions :

  - agrégation : rassembler les informations des différentes sondes.

  - fusion : fusionner en supprimant les doublons (même attaque détectée par plusieurs sondes).

  - corrélation : définir un motif commun, c'est-à-dire interpréter une suite d'événements et les résumer.
- ⇒ Une corrélation intéressante serait de ne garder que les alertes qui concernent une faille probable du système.

6.6.2 Les outils

- Snort : système de détection d'intrusion libre publié sous licence GNU GPL.
- ACID (Analysis Console for Intrusion Databases) : outil d'administration d'un IDS permettant de se connecter à la base de données de SNORT.

Chapitre 7 Iptables : Parfeu Linux

7.1 Définition

Un **pare-feu** (en anglais firewall) est un logiciel et/ou un matériel permettant de faire respecter la politique de sécurité du réseau, celle-ci définissant quels sont les types de communications autorisés sur ce réseau informatique.

Il surveille et contrôle les applications et les flux de données (paquets).

7.2 Iptables: Configuration des tables et chaînes du pare-feu intégré

Le pare-feu Iptables se compose de plusieurs tables et chaînes pour la configuration.

Les paramètres permettent d'autoriser ou de bloquer les paquets entrant, sortant et traversant votre machine.

Il existe 4 tables dans Iptables:
La première est la table par défault, les nouvelles règles y sont ajoutées lorsque aucune table n'a été spécifié.
filter => L'emplacement prévu pour ajouter des filtres sur les paquets entrant, sortant et traversant.
nat => Permet de faire la traduction d'adresse réseau (NAT) sur différents paquets.
mangle => Permet de modifier des paquets en changeant les champs de TOS (type de service), et d'autres ...

L'utilisation de la table filter marche de la même façon que la table par défaut.

Filter est la table par défaut.
C'est la table utilisée pour définir les règles de pare-feu de la machine.
En effet, cette table ***filter*** permet de bloquer ou autoriser les paquets qui entrent et sortent.

On y trouve les chaines :

- **INPUT** : Les paquets à destination de la machine. En général, à destination des processus locaux.
- **OUTPUT** : Les paquets sortant de la machine, en général, provenant des processus locaux.
- **FORWARD** : Les paquets qui passent à travers le serveur, par exemple, d'une interface réseau à l'autre ou à destination d'une autre machine sur le réseau. Cette chaine est utilisée lorsque la machine joue le rôle de routeur.

7.2.1 Table nat

La table NAT contient les chaînes suivantes :

- **PREROUTING** : Modifier les paquets AVANT leurs routages. En clair cela, vous permet de rediriger un paquet vers une autre destination en modifiant l'IP de destination par exemple (DNAT – Destination NAT)

- **POSTROUTING** : Modifier les paquets APRES le routage. Cela permet de modifier par exemple l'IP source, SNAT (Source NAT).
- **OUTPUT :** NAT pour les paquets générés par le pare-feu.

7.2.2 Table mangle

La tables Mangle permet de modifier les paquets, elle est surtout utile pour effectuer de la QoS.
Cette table ne doit pas être utilisé pour modifier les IPs source/destination pour effectuer du NAT.

Les chaînes de la table Mangle. On retrouve les mêmes que précédemment, avec les mêmes conditions.

- PREROUTING
- OUTPUT
- FORWARD
- INPUT
- POSTROUTING

7.2.3 Syntaxe d'iptables

iptables [-t table] [Action] [Options Valeur] [Cible]
Quelque options:
-p protocol
-s adresse_ip: IP source
-d adresse_ip: IP de destination
-j Cible: règle (LOG, ACCEPT, REJECT, DENY, DROP)
-i "Input Interface"
-o "Output Interface"
--dport Le numéro de port
--line-numbers: Afficher les numéros de ligne des règles

Lister les règles actuelles (-L)

```
# iptables -L

Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

Ordre d'application des règles :

Dans iptables, les règles sont traitées dans l'ordre dans lequel elles sont spécifiées.

Lorsqu'un paquet arrive sur une interface, iptables va le comparer aux règles dans chacune des chaînes pour déterminer à quelle règle il correspond en premier.

Une fois qu'une règle correspond, elle est appliquée et le traitement des règles s'arrête là.

Comment les règles sont priorisées :

- **Politique par défaut** : Les politiques par défaut définissent ce qui se passe pour les paquets qui ne correspondent à aucune règle dans la chaîne. Vous pouvez définir ces politiques en utilisant les commandes iptables -P.
- **Ordre des règles** : Les règles sont traitées dans l'ordre où elles sont spécifiées. La première règle qui correspond à un paquet est appliquée, et le traitement des règles s'arrête là.
- **Les règles plus spécifiques ont la priorité** : Si deux règles sont en conflit, la règle la plus spécifique est appliquée en premier. Par exemple, une règle qui correspond à une adresse IP spécifique aura la priorité sur une règle qui correspond à une plage d'adresses IP.

Exemple :

```
iptables -A INPUT -s 192.168.1.100 -j DROP
iptables -A INPUT -s 192.168.1.0/24 -j ACCEPT
```

Dans cet exemple, si un paquet provient de l'adresse IP 192.168.1.100, il sera bloqué par la première règle car elle est plus spécifique, et la deuxième règle ne sera pas appliquée.

Si le paquet provient d'une autre adresse IP de la plage 192.168.1.0/24, il sera accepté grâce à la deuxième règle.

Ajouter une règle pour un port (-A ou -I)

On va autoriser le trafic http entrant sur le port "80" de l'interface "eth0".

```
# iptables -A INPUT -p tcp -i eth0 --dport 80 -j ACCEPT
```

- Le paramètre -A (append) permet de modifier une chaîne, la règle sera créée à la fin de la chaîne.
- Le paramètre -I (insert) permet d'ajouter une règle en début de chaîne.
- -p Pour choisir le protocole, dans ce cas c'est "tcp "
  - -i Pour l'interface où la règle sera appliquée
  - --dport Pour le numéro de port, là c'est "80 "

- -j Pour l'autorisation

On va ajouter une autre règle pour autoriser les connexions ftp entrantes.

```
# iptables -A INPUT -p tcp -i eth0 --dport 21 -j ACCEPT
```

Et aussi le SSH.

```
# iptables -A INPUT -p tcp -i eth0 --dport 22 -j ACCEPT
```

Maintenant on va afficher la liste pour voir nos 3 nouvelles règles

```
s -L -v -n
UT (policy ACCEPT 8 packets, 608 bytes)
es target     prot opt in     out     source               destination
 0 ACCEPT     tcp  --  eth0   *       0.0.0.0/0            0.0.0.0/0           tcp dpt:80
 0 ACCEPT     tcp  --  eth0   *       0.0.0.0/0            0.0.0.0/0           tcp dpt:21
 0 ACCEPT     tcp  --  eth0   *       0.0.0.0/0            0.0.0.0/0           tcp dpt:22
```

On peut autoriser le trafic entrant d'une connexion déjà ouverte.

```
# iptables -A INPUT -m state --state ESTABLISHED -j ACCEPT
```

On voit cette nouvelle règle à la 4ème ligne des chaines INPUT

```
v -n
licy ACCEPT 0 packets, 0 bytes)
get     prot opt in     out     source               destination
EPT     tcp  --  eth0   *       0.0.0.0/0            0.0.0.0/0           tcp dpt:80
EPT     tcp  --  eth0   *       0.0.0.0/0            0.0.0.0/0           tcp dpt:21
EPT     tcp  --  eth0   *       0.0.0.0/0            0.0.0.0/0           tcp dpt:22
EPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0           state ESTABLISHED
```

Quand vous affichez vos règles, les paramètres des politiques s'affichent juste après "policy". Dans l'exemple ci-dessous, la chaine "INPUT" avec la politique "ACCEPT" permet d'autoriser tout le trafic entrant.

```
# iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:www
ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ftp
ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ssh
ACCEPT     all  --  anywhere             anywhere            state ESTABLISHED
...
```

Mais pour autoriser que le trafic entrant spécifié dans les règles INPUT, on va utiliser la commande "-P".
Syntaxe:
iptables -P [chaine] [politique]
On va par exemple mettre la politique de bloquer(DROP) sur le trafic entrant(INPUT):

```
iptables -P INPUT DROP
```

On vérifie la politique :

```
# iptables -L
Chain INPUT (policy DROP)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:www
ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ftp
ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ssh
ACCEPT     all  --  anywhere             anywhere            state ESTABLISHED
```

Autoriser l'interface locale

Quand vous changez de politique pensez à autoriser l'exécution de l'interface locale(loopback) pour permettre aux applications sur la machine elle-même de communiquer entre elles.

Par exemple, un serveur web peut avoir besoin de communiquer avec un serveur de base de données sur la même machine via localhost.

```
# iptables -I INPUT -i lo -j ACCEPT
```

Insérer une règle dans un certain ordre(-I)

Pour commencer, on va lister les règles avec un numéro par ligne.

```
# iptables -L --line-numbers
Chain INPUT (policy DROP)
num  target     prot opt source               destination
1    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:www
2    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ftp
3    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ssh
4    ACCEPT     all  --  anywhere             anywhere            state ESTABLISHED
```

On va insérer en 3ème ligne de la chaine "INPUT", l'autorisation du ping entrant (requêtes ICMP). Puis, On vérifie que la règle s'affiche en 3ème ligne :

```
# iptables -I INPUT 3 -p icmp -j ACCEPT
```

```
# iptables -L --line-numbers
Chain INPUT (policy DROP)
num  target     prot opt source               destination
1    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:www
2    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ftp
3    ACCEPT     icmp --  anywhere             anywhere
4    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ssh
5    ACCEPT     all  --  anywhere             anywhere            state ESTABLISHED
```

Supprimer une règle d'autorisation(-D)

Pour commencer, on va lister les règles avec un numéro par ligne.

```
# iptables -L --line-numbers
Chain INPUT (policy DROP)
num  target     prot opt source               destination
1    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:www
2    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ftp
3    ACCEPT     icmp --  anywhere             anywhere
4    ACCEPT     tcp  --  anywhere             anywhere            tcp dpt:ssh
5    ACCEPT     all  --  anywhere             anywhere            state ESTABLISHED
```

Dans notre exemple on va supprimer les autorisations entrantes du "SSH" qui est sur la ligne "4" de la chaine "INPUT".
Syntaxe: **iptables -D [chaine] [numéro_de_ligne]**
Exemple:

```
iptables -D INPUT 4
```

Règles de la chaine FORWARD

- La chaine "FORWARD" permet d'autoriser à retransmettre (router) des paquets d'une interface à une autre.
- Il faut tout d'abord activer le forward c-à-d **Activer le routage des paquets IP, des datagrammes**

Vérifiez d'abord l'état de l'IP Forwarding en tapant la commande suivante :

```
cat /proc/sys/net/ipv4/ip_forward
```

- Si la commande retourne la valeur 0, c'est que l'IP Forwarding n'est pas activé.
- Et si la commande retourne la valeur 1, c'est que l'IP Forwarding est activé.

Activer le routage IP et rendre le routage permanent

Pour l'activer, il suffit de taper la commande :

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

Nous voulons éditer le fichier "sysctl.conf" dans le répertoire "/etc" pour rendre cette configuration permanente :

```
nano /etc/sysctl.conf
```

Et ajouter cette ligne si elle n'existe pas. Si la ligne existe dans le fichier, vérifier bien qu'elle n'est pas commentée (il n'y a pas de "#" en début de ligne).

```
net.ipv4.ip_forward=1
```

Pour activer les changements effectués dans Sysctl.Conf ,vous aurez besoin de la commande:

```
sysctl -p /etc/sysctl.conf
```

Une fois le routage est activé, autoriser à retransmettre des paquets en entrée(-i) et en sortie(-o) sur l'interface "eth0".

```
iptables -A FORWARD -i eth0 -j ACCEPT
iptables -A FORWARD -o eth0 -j ACCEPT
```

Par exemple pour autoriser à retransmettre des paquets en entrée(-i) de l'interface "eth0" vers la sortie(-o) sur l'interface "eth1" et dans la deuxième ligne dans l'autre sens :

```
iptables -A FORWARD -i eth0 -o eth1 -j ACCEPT
iptables -A FORWARD -i eth1 -o eth0 -j ACCEPT
```

Réinitialiser la configuration -F

Pour nettoyer toutes les règles de la configuration de votre pare-feu:

```
iptables -F
iptables -X
```

7.3 Iptables: Configurer la table NAT du pare-feu

La table nat permet de faire la translation d'adresse réseau (NAT) sur différents paquets.

La traduction d'adresse est gérée avec les chaînes PREROUTING, POSTROUTING et OUTPUT.
Voici la structure de test utilisée pour les exemples qui suivent :

```
                            +------------+                      +-------------+
MODEM                       |   Linux    |                      |   Poste     |
+---+192.168.1.1            |            |193.168.1.10           |             |
|   |<--------------------->| Passerelle |<--------------------->|   Client    |
+---+          192.168.1.199|            |           193.168.1.15|             |
                            |    NAT     |                      |             |
                            +------------+                      +-------------+
```

7.3.1 Le DNAT ou NAT Destination

La chaîne PREROUTING (avant routage) permet de modifier que l'adresse de destination mais conserve l'adresse source.
C'est ce qu'on appelle faire du DNAT (NAT destination).

Dans cet exemple, on va rediriger le trafic en destination du réseau "195.111.222.0" vers le réseau "193.168.1.0".

iptables -t nat -A PREROUTING -d 195.111.222.0/24 -j DNAT --to-destination 193.168.1.0/24

7.3.2 Le SNAT ou NAT Source

La chaîne POSTROUTING (après routage) permet de modifier que l'adresse source mais conserve l'adresse de destination.

C'est ce qu'on appelle faire du SNAT (NAT source).

Dans cet exemple, on va substituer l'adresse source du trafic privé sortant vers l'extérieur par une des adresses publiques spécifiées.

iptables -t nat -A POSTROUTING -s 193.168.1.0/24 -j SNAT --to-source 192.168.1.5-192.168.1.8

7.3.3 L'IP Masquerade

Le principe est d'utiliser une adresse IP publique source pour cacher derrière elle toutes les adresses IP du réseau privé.

Dans cet exemple avec du SNAT, tous les paquets provenant du réseau privé 193.168.1.0 seront perçus comme provenant de l'IP public 192.168.1.199.
iptables -t nat -A POSTROUTING -s 193.168.1.0/24 -j SNAT --to-source 192.168.1.199

Il y a aussi l'option "MASQUERADE" qui a le même but.
iptables -t nat -A POSTROUTING -s 193.168.1.0/24 -j MASQUERADE

Vous pouvez utiliser d'autres options, comme choisir par rapport à votre interface réseau , ici "eth0" et au numéro de port, dans ce cas "80".
iptables -t nat -A POSTROUTING -o eth0 --dport 80 -j MASQUERADE

Afficher la table NAT du parfeu :

```
# iptables -t nat -L
Chain PREROUTING (policy ACCEPT)
target     prot opt source               destination

Chain POSTROUTING (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

Chapitre 8 Proxy

8.1 Introduction

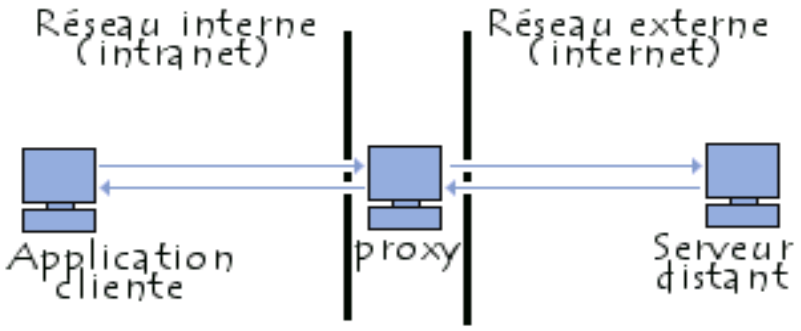
Un serveur **proxy** (traduction française de «*proxy server*», appelé aussi «*serveur mandataire*») est à l'origine une machine faisant fonction d'intermédiaire entre les ordinateurs d'un réseau local et internet.

La plupart du temps le serveur proxy est utilisé pour le web, il s'agit alors d'un proxy HTTP. Toutefois il peut exister des serveurs proxy pour chaque protocole applicatif (FTP, ...)

8.2 Principe de fonctionnement d'un proxy

Il s'agit d'un serveur "mandaté" par une application pour effectuer une requête sur Internet à sa place.

Lorsqu'un utilisateur se connecte à internet à l'aide d'une application cliente configurée pour utiliser un serveur proxy, celle-ci va se connecter en premier lieu au serveur proxy et lui donner sa requête. Le serveur proxy va alors se connecter au serveur que l'application cliente cherche à joindre et lui transmettre la requête. Le serveur va ensuite donner sa réponse au proxy, qui va à son tour la transmettre à l'application cliente.



8.3 Les fonctionnalités d'un serveur proxy

Désormais, avec l'utilisation de TCP/IP au sein des réseaux locaux, le rôle de relais du serveur proxy est directement assuré par les passerelles et les routeurs.

Pour autant, les serveurs proxy sont toujours d'actualité grâce à un certain nombre d'autres fonctionnalités.

8.3.1 La fonction de cache

La plupart des proxys assurent ainsi une fonction de **cache**, c'est-à-dire la capacité à garder en mémoire (en *"cache"*) les pages les plus souvent visitées par les utilisateurs du réseau local afin de pouvoir les leur fournir le plus rapidement possible. En effet, en informatique, le terme

de "cache" désigne un espace de stockage temporaire de données (le terme de "tampon" est également parfois utilisé).

Un serveur proxy ayant la possibilité de cacher ("mettre en mémoire cache") les informations est généralement appelé "serveur **proxy-cache**".

Cette fonctionnalité implémentée dans certains serveurs proxy permet d'une part de réduire l'utilisation de la bande passante vers internet ainsi que de réduire le temps d'accès aux documents pour les utilisateurs.

Toutefois, pour mener à bien cette mission, il est nécessaire que le proxy compare régulièrement les données qu'il stocke en mémoire cache avec les données distantes afin de s'assurer que les données en cache sont toujours valides.

8.3.2 Le filtrage

Il est possible de filtrer les connexions à internet en analysant d'une part les requêtes des clients, d'autre part les réponses des serveurs.

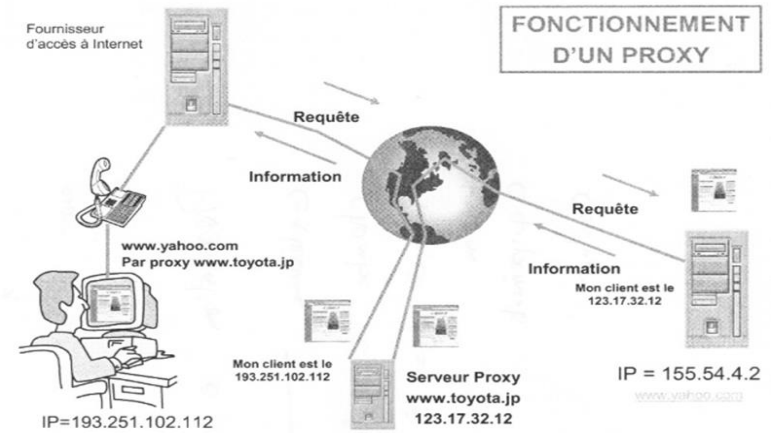
Lorsque le filtrage est réalisé en comparant la requête du client à une liste de requêtes autorisées, on parle de *liste blanche.*

Lorsqu'il s'agit d'une liste de sites interdits on parle de *liste noire*. Enfin l'analyse des réponses des serveurs conformément à une liste de critères (mots-clés, ...) est appelé *filtrage de contenu*.

8.3.3 L'authentification

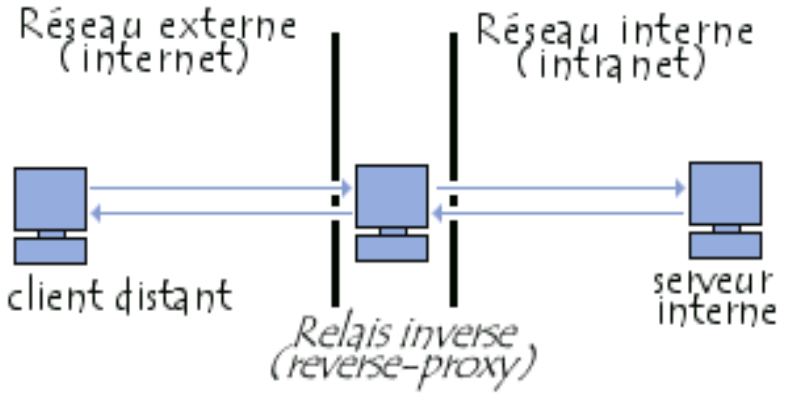
Il est parfois possible de l'utiliser pour authentifier les utilisateurs. Il est ainsi aisé de donner l'accès aux ressources externes aux seules personnes autorisées à le faire et de pouvoir enregistrer dans les fichiers journaux des accès identifiés.

Ce type de mécanisme lorsqu'il est mis en œuvre pose bien évidemment de nombreux problèmes relatifs aux libertés individuelles et aux droits des personnes.



8.4 Les reverse-proxy

On appelle *reverse-proxy* un serveur proxy-cache "monté à l'envers", c'est-à-dire un serveur proxy permettant non pas aux utilisateurs d'accéder au réseau internet, mais aux utilisateurs d'internet d'accéder indirectement à certains serveurs internes.



Grâce au reverse-proxy, le serveur web est protégé des attaques directes de l'extérieur, ce qui renforce la sécurité du réseau interne.

La fonction de cache du reverse-proxy peut permettre de soulager la charge du serveur pour lequel il est prévu, c'est la raison pour laquelle un tel serveur est parfois appelé "accélérateur" (*server accelerator*).

Enfin, grâce à des algorithmes perfectionnés, le reverse-proxy peut servir à répartir la charge en redirigeant les requêtes vers différents serveurs équivalents ; on parle alors de "répartition de charge", ou en anglais "*load balancing*".

8.4.1 Mise en place d'un serveur proxy

Le proxy le plus répandu est Squid, un logiciel libre disponible sur de nombreuses plates-formes dont Windows et Linux.